Bases Técnicas

Solución de Gobierno, Riesgo y Cumplimiento (GRC) - BancoEstado

Febrero 2022

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Índice

1. Introducción 6
2. Objetivo 7
3. Definiciones Específicas Técnicas de la Plataforma a Licitar 9
3.1. Riesgo Operacional 9
3.2. Continuidad de Negocio 17
3.3. Analítica 18
3.4. Experiencia Usuario 18
3.5. Demo 19
4. Identificación de los Servicios Requeridos 19
4.1.1. Integración con otros Sistemas / Plataformas / Sitios 19
4.1.2. Publicación / Descarga / Emisión archivos y/o documentos 20
4.1.2.1. Publicación de archivos y/o descarga de archivos 20
4.1.3. Perfiles y Ambientes de Navegación 20
4.1.4. Experiencia Usuario 21
4.1.5. Directorio Activo 22
4.1.6. Reportería / Dashboard / Tableros 22
4.1.7. Tracking 23
4.1.8. Soporte 23
4.1.8.1. Soporte Funcional / Configuración (Perfil Administrador) 24
4.1.8.2. Soporte Rol General del Usuario 24
4.2. Servicios Específicos 25
4.2.1. Riesgo Operacional 25
4.2.1.1. Registro de Matrices de Riesgo 25

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

4.2.1.2. Gestión de los Riesgos 26
4.2.1.3. Gestión de KRI (indicadores claves de Riesgo) 27
4.2.1.4. Gestión Plan de Acción 28
4.2.2. Continuidad de Negocio 34
4.2.2.1. Registro de BIA/RIA 34
4.2.2.2. Planes de Contingencia 49
4.2.2.3. Gestión de Continuidad de Negocio 54
4.2.3. Base de Pérdida 55
4.2.3.1. Gestión de pérdidas y Apetito de riesgo 55
4.2.4. Contraloría (Auditoría Interna) 56
4.2.4.1. Planificación para un Periodo 56
4.2.4.2. Seguimiento de Observaciones 60
4.2.4.3. Información de Gestión y Control de Calidad 61
4.2.5. Reportes 62
4.2.6. Demo 62
4.3. Plazo del servicio 62
4.4. Horario del servicio 63
4.5. Estrategia de Implementación y puesta en marcha del servicio 63
5. Requerimientos Técnicos 64
5.1. Arquitectura Aplicativa 64
5.1.1. Requerimientos Generales 64
5.1.1.1. Mecanismo de integración Batch 64
5.1.1.2. Navegadores estándar Banco 65
5.1.1.3. Responsividad de la solución 65

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.1.1.4. Autenticación 65
5.1.1.5. Autorización 66
5.1.1.6. Administración de la autorización de la solución 66
5.1.1.7. Tiempos de respuesta portal web 66
5.1.1.8. Información digitalizada en la solución 66
5.1.1.9. Ambiente DevOps 66
5.1.1.10. Envío de correos con dominio BancoEstado 66
5.2. Arquitectura Técnica 67
5.2.1. Requerimientos Tecnológicos 67
5.2.1.1. Entorno de computación en la nube 67
5.2.1.2. Requerimientos de Experiencia del oferente 68
5.2.1.3. Requerimientos técnicos para una Solución SaaS 68
5.2.1.4. Recuperación ante desastres y continuidad del Servicio 69
5.2.1.5. Servicio de Migración e implementación de la Solución 69
5.2.1.6. Modelo de Operación del Servicio 70
5.2.1.6.1. Servicio de Monitoreo 70
5.2.1.6.2. Servicio de Atención de Soporte Tecnológico 71
5.3. Arquitectura de Seguridad 72
5.3.1. Requerimientos Generales de Seguridad para el Proveedor del Servicio 72
5.3.1.1. Gobierno y políticas 72
5.3.1.2. Disponibilidad y niveles de servicio 73
5.3.1.3. Continuidad 73
5.3.1.4. Auditoría 74
5.3.2. Requerimientos Tecnológicos de Seguridad 75

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.3.2.1. Control de fuga de información y seguridad perimetral 75

5.3.2.2. Equipamiento tecnológico 76

5.3.2.3. Control de acceso 77

5.3.2.4. Control de Acceso Perimetral 79

5.3.2.5. Desarrollo Seguro de Software 80

5.3.2.6. Codificación Segura 84

5.3.2.7. Criptografía 85

5.3.2.8. Servicios de Red 87

5.3.2.9. Transferencia de información 88

5.3.2.10. Log de eventos 95

5.3.2.11. Respaldo de Información 97

5.3.2.12. Borrado y destrucción segura de información 98

5.3.2.13. Requerimientos de Seguridad en Datos en Reposo en la Nube o Sitio externo 101 100

5.3.2.14. Centros de datos (Datacenter) e infraestructura TI 100

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

1. Introducción

El Banco del Estado de Chile, en adelante también e indistintamente “BancoEstado” o “el Banco”, inicia un proceso de licitación para contratar una solución de Gobierno Corporativo, Análisis Gestión de Riesgo y Cumplimiento Normativo (GRC), que cubra en principio las necesidades de la Gerencia de Riesgos no Financieros y de la Contraloría (Auditoría Interna), que además permita la integración y sinergia dado sus roles

El presente documento regula los aspectos del servicio, cuyo detalle corresponde determinar a la respectiva área usuaria del bien o servicio que se requiere.

La licitación se convoca por invitación privada y tiene por objeto recibir las ofertas que presenten los proveedores que deseen adjudicarse la propuesta señalada. Entre las ofertas que se reciban dentro del plazo y cumplan con los requisitos establecidos en estas Bases, el Banco del Estado de Chile resolverá libremente, sin expresión de causa, sobre la aceptación o rechazo de lo propuesto, reservándose por tanto el derecho de declarar desierta la licitación, si así lo estima conveniente.

El presente proceso de licitación que rige a partir de este llamado a participar, hasta la comunicación de la adjudicación del o los servicios y la posterior firma del respectivo contrato, será administrado por la Subgerencia de Compras de BancoEstado.

Las especificaciones que se presentan en este documento constituyen los fundamentos sobre los cuales los oferentes deben formular y construir sus ofertas.

El Banco espera que el proveedor presente una propuesta integral con un único contrato de servicio que incluya todos los módulos establecidos en las bases técnicas, independiente que hubiera otras empresas relacionadas o integradas con el proveedor.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

2. Objetivo

El objetivo de las presentes bases es entregar las especificaciones técnicas del servicio objeto de esta licitación, que permita al proveedor formular y construir sus ofertas, las que el Banco considerará para su análisis.

En consecuencia, el oferente que se interese en satisfacer las condiciones de este requerimiento de servicio deberá considerar, en todo momento, que la solución que BancoEstado desea satisfacer apunta hacia una solución integral compuesta por: arriendo y soporte en la administración de la Plataforma Integral de los Servicios a adjudicar, los cuales pudieran abarcar todos los ámbitos descritos anteriormente o solamente una parte de ellos.

BancoEstado está buscando adquirir una Plataforma Integral de gobierno corporativo, análisis y gestión de riesgo y cumplimiento normativo, así como Auditoría Interna; con el fin de visualizar de manera transversal los riesgos y así mejorar la gestión de ellos, mejorando su eficiencia y oportunidad, orientado a:

- Apalancar uno de los objetivos estratégicos del Banco y de la Gerencia de Riesgos no Financieros, que consiste en automatizar/digitalizar las materias de riesgo operacional, en el ámbito de procesos y continuidad del negocio.
- Disminuir la exposición a riesgos operacionales dada la alta manualidad que actualmente se opera en la identificación de los riesgos, así como en el seguimiento de los controles necesarios para la mitigación de estos.
- Mejorar la gestión de los riesgos, toma de decisiones oportunas, mitigar amenazas, optimizar los recursos y capacidades de los equipos, facilitando la coordinación y colaboración de estos.
- Ampliar la cobertura de los procesos que son objeto de análisis en la identificación de los riesgos.
- Monitorear y coordinar las políticas y controles corporativos.
- Revisar y evaluar los riesgos de Banco considerando aquellos que puedan afectar los objetivos de negocio.
- Mapear y relacionar controles con requisitos de cumplimiento interno y normativo.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Cumplir con lo comprometido con el regulador en automatizar las materias de la Gerencia de Riesgos no Financieros.
- En el caso de Contraloría (Auditoría Interna), migrar a sistemas web-nube que permitan una mayor flexibilidad en la gestión y en línea con la estrategia tecnológica Banco.
- A nivel transversal Banco, integrar la información sobre riesgos y controles, de modo de generar coordinación y sinergía entre las distintas líneas y roles, generando retroalimentación, respecto de la gestión de riesgos para contribuir al logro de la estrategia y objetivos corporativos. Lo anterior es posible, dado que existen criterios corporativos definidos desde hace unos años entre las Áreas de Riesgo Operacional y Contraloría, respecto de impactos, probabilidades, mapa de calor, diseño de controles, eficacia operativa, entre otros, así como también el acuerdo de trabajar alineados sobre un mismo universo de procesos y tipología de riesgos.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

3. Definiciones Específicas Técnicas de la Plataforma a Licitar

Se entenderá como solución de gobierno corporativo, análisis y gestión de riesgo y cumplimiento normativo, aquella que permita gestionar los riesgos, indicadores, controles y seguimiento de planes de acción. Además, de gestionar/vincular el tratamiento de algunos tipos de riesgos relevantes como son la continuidad del negocio BIA/RIA y BCP/DRP e incidentes o eventos de pérdidas. De la misma manera, integrar y comunicar la información y análisis de riesgos y controles entre las distintas líneas y roles, en particular, entre la Gerencia de Riesgos no Financieros y la Contraloría (Auditoría Interna) donde se lleva un seguimiento de las observaciones productos de las auditoría interna, de acuerdo a perfiles y responsabilidades.

La Plataforma debe garantizar la Confidencialidad, Disponibilidad e Integridad de la información que se gestionará a través de la herramienta

Debe comunicarse con el directorio activo del Banco. Si la herramienta genera correos, debe aceptar la información de usuario genérico Banco.

3.1. Riesgo Operacional

Riesgo Operacional

El riesgo operacional se define como el riesgo de pérdida debido a la inadecuación o a fallas de los procesos, el personal y los sistemas internos o bien a causa de acontecimientos externos. Esta definición incluye el riesgo legal, pero excluye el riesgo estratégico, el de imagen y el de reputación.

Control

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Es el conjunto de actividades tendientes a Prevenir, Mitigar o Detectar la materialización de un riesgo. El control debe considerar registrar ¿Qué?, ¿Quién?, ¿Donde?, ¿Cuándo?, ¿Por qué? y ¿Cómo?

Riesgo

Es la probabilidad de sufrir alguna forma de daño o Pérdida, se mide en base a distintos factores considerando impacto y probabilidad.

En el caso del impacto se analiza en cuál de los siguientes ámbitos aplica Clientes, Monetario, Proceso, Normativo y Reputacional.

Para la probabilidad se considera Frecuencia y Ocurrencia.

Riesgo Inherente

Es el Riesgo intrínseco a cualquier actividad, sólo por el hecho de existir. Para disminuirlo, una entidad necesita contar con Controles o Mitigadores, que disminuyan su probabilidad de ocurrencia y/o el impacto que puede producir.

A nivel de Diseño del Control

Evaluación del Control	Oportunidad del Control	Alcance del Control	Automatización	Formalización / Evidencia
Deficiente	No existe, o No se ejecuta, o Correctivo	Cobertura parcial	Manual sin segregación de funciones	No está formalizado y no tiene registros de su ejecución
Regular	Detectivo	Cobertura parcial	Manual con segregación de funciones	No está formalizado, pero tiene registro de su ejecución
Suficiente	Detectivo	Abarca todas las operaciones	Control manual o semiautomático con contraposición de funciones	Está formalizado y tiene registro de su ejecución
Bueno	Preventivo	Abarca todas las operaciones	Semiautomático con contraposición de funciones	Está formalizado y difundido, tiene registro de su ejecución
Óptimo	Preventivo	Abarca todas las operaciones	Control automático con monitoreo	Está formalizado y difundido, tiene registro de su ejecución y se hace monitoreo sobre su desempeño

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

A nivel de Eficacia Operativa (Cumplimiento): en base a la ejecución de pruebas de auditoría, se verificarán excepciones o casos, las cuales según su % en relación a lo revisado, se clasificarán de la siguiente manera.

BETA CUMPLIMIENTO 50%

ALTA Menos del 1% de excepciones de lo revisado o las desviaciones están dentro del umbral definido como verde.

MEDIA Hasta un 2% de excepciones de lo revisado o las desviaciones están dentro del umbral definido como amarillo.

BAJA Las excepciones están sobre un 2% de o revisado o las desviaciones están en el umbral definido como rojo.

Efectividad Final del Control

DISEÑO		EFICACIA OPERATIVA	BETA CUMPLIMIENTO
Evaluación del Control			
Deficiente			
Regular			
Suficiente		ALTA	100%
Bueno	X	MEDIA	80%
Óptimo		BAJA	50%

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Riesgo Residual

Es el Riesgo que permanece después de que se han desarrollado mecanismos de control y mitigación. Controles eficientes y robustos pueden convertir actividades con riesgos inherentes altos, en actividades con riesgos residuales pequeños.

Para calcular el Riesgo Inherente y Residual, se utilizan las siguientes fórmulas:

Riesgo Inherente	Impacto x Probabilidad
Riesgo Residual	Nivel de Riesgo Inherente Nivel de Efectividad de control

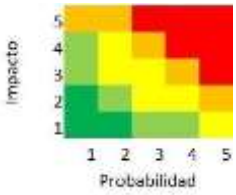
La Escala de Riesgo Inherente y Riesgo Residual, es la siguiente:

Rango		Riesgo Inherente
15	25	Alto
10	14,99	Medio Alto
5	9,99	Medio
3	4,99	Medio Bajo
1	2,00	Bajo

NOTA: En el caso particular de los riesgos de Alto Impacto (5) y baja probabilidad (1) se decide graduar este riesgo como MEDIO ALTO.

Rango		Riesgo Residual
15	25	Alto
10	14,99	Medio Alto
5	9,99	Medio
3	4,99	Medio Bajo
1	2,00	Bajo

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile



Indicadores KRI

Los indicadores claves de Riesgo (KRI) son métricas que permiten advertir en forma temprana sobre la materialización de riesgos de pérdida y la eficiencia y efectividad de los controles implementados. En general estos indicadores proveen alertas de posibles exposiciones para generar proactividad en la administración del Riesgo Operacional.

Existen dos clases de indicadores de riesgo

Preventivos

Corresponde a indicadores donde el riesgo existe, pero no se ha materializado una pérdida o una ocurrencia de eventos, éstos tienen la característica que alertar para el potencial aumento en la materialización de pérdidas u ocurrencia de eventos de riesgo.

Detectives

Corresponden a indicadores donde el evento o la pérdida ya se materializaron en forma parcial o total y son indicadores que permiten proveer de información útil para descubrir patrones o tendencias en las pérdidas o eventos ocurridos.

Cada indicador debe tener la capacidad de ser medido con precisión y reflejar de manera precisa el impacto negativo, deben ser dinámicos (integrarse con otras aplicaciones que calculan y retroalimentan el indicador), poder modificarse en el tiempo y en la medida de lo posible deben estar directamente relacionados con el riesgo que ha sido identificado, ya sea en su dimensión detective o preventiva.

Para la definición de los indicadores de riesgo, es importante establecer parámetros mínimos:

- Nombre del indicador.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Lo que el indicador medirá.
- Método de cálculo para obtención del indicador.
- Periodicidad en la medición.

Cada indicador de riesgo debe poseer un criterio de aceptación o límite de tolerancia específico, para facilitar el monitoreo y la interpretación de sus resultados. Los límites son definidos por medio de valores que pueden transitar por zonas o bandas, cuya interpretación de resultados asociados puede ser establecida de la siguiente manera:

- Zona Verde: Corresponde al criterio de aceptación o límite esperado para el indicador y señala que la Corporación no hay exposición al riesgo más allá de lo esperado.
- Zona Amarilla: Representa una variación en relación al criterio de aceptación o límite. Por lo tanto, su resultado comunica un posible aumento potencial de la exposición al riesgo.
- Zona Roja: Significa que la tolerancia al riesgo fue excedida y que existe exposición significativa. Existe la necesidad de análisis y comunicación en los foros definidos para la definición de planes de acción.

Plan de Acción de Riesgo Operacional

Un plan de acción de riesgo operacional consta de un conjunto de acciones relacionadas con alguna técnica de administración (Evitar, Mitigar, Transferir) para los riesgos que se encuentran sub controlados. Este debe quedar registrado en una ***Matriz de Riesgo – Planes de Acción.***

Un plan de acción describe las responsabilidades y acciones que se deben desarrollar en relación a los riesgos identificados y como mitigarlos. Algunas técnicas que pueden ser utilizadas en la determinación de estos planes son:

- Mitigar: Establecer una serie de controles que permiten minimizar el impacto y/o probabilidad.
- Transferir: Traspasar el riesgo a otra compañía (outsourcing, póliza de seguro).
- Evitar: Frente a un riesgo alto, se tome la decisión de terminar el servicio o venta de un producto.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Aceptar: Asumir el riesgo potencial sin tomar ninguna medida. (Relacionado a la tolerancia al riesgo que se está dispuesto a asumir, el que deberá ser presentado en Comité de Riesgo Operacional y Tecnológico).

Los campos que considera un Plan de Acción ID, Área específica, Jefatura, Responsable Seguimiento, Responsable Ejecución, Planes de acción, Nivel de Riesgo (RR), Proceso / Servicio Asociado, Informe de Riesgo/ Matriz de Riesgo/ KRI fuera de umbral / Prueba continuidad / Monitoreo control, Fecha de ingreso, Fecha anterior 2da Reprogramación, Fecha anterior 1era Reprogramación, Fecha comprometida, Fecha máxima de entrega, Fecha de finalización real, % de avance actual, % de avance esperado, Descripción del avance.

La metodología exigirá la implementación de planes de acción en las siguientes situaciones:

- A partir de la identificación de desviaciones en los indicadores de riesgo definidos, es decir, resultados excedidos en los criterios de aceptación o límites por un periodo de tres meses consecutivos, se debe analizar la necesidad de la definición e implementación de planes de acción en esta circunstancia tomando en cuenta que la desviación puede deberse a una situación puntual versus una que presente causas raíces.
- Si la certificación de los controles de los riesgos inherentes Alto y Medio Alto no fueron satisfactorios y la efectividad en el diseño y/o su ejecución resultó poco efectivo, se deberán comprometer planes de acción para su mejora.
- Al confeccionar la matriz de riesgo definitiva de cada proceso que contenga riesgos residuales que resulten significativos, es decir, Altos o Medio Altos, se deberán comprometer planes de acción con una fecha límite de compromiso. Pueden existir excepciones.

Se deja la posibilidad de que por análisis de riesgos presentados ya sea por el analista de Riesgos o a solicitud del responsable de proceso, se soliciten planes de acción para aquellos riesgos residuales clasificados bajos o moderados, los cuales una vez que han sido comprometidos, deberán regirse por los monitoreos establecidos.

Factor de Riesgo

Es un hecho no deseado que favorece la materialización de un evento de pérdida.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Riesgo de Pérdida

Es un hecho no deseado que se traduce en una pérdida potencial para el Banco. Los riesgos de pérdida se materializan producto de la ocurrencia de uno o más factores de riesgo.

Gestión de pérdidas y Apetito de riesgo

La Gerencia de Riesgos no Financieros ha generado un modelo para contar con una fuente confiable de eventos de pérdida por riesgo operacional, para lo cual ha definido la existencia de una base de datos de pérdidas, que se alimenta de datos formales y confiables de la Corporación, a partir de un proceso de recolección, no solo con el objetivo de registrar las pérdidas sino que también entender sus causas raíces y poder realizar seguimientos adecuados respecto si las pérdidas están acorde con lo aceptado por la alta administración.

Apetito de Riesgo

Se ha definido un apetito de riesgo operacional, basado en un ratio que combina las pérdidas operacionales y la actividad económica de la entidad. Para la cuantificación de las pérdidas se utiliza el Total de Pérdidas Operacionales, que emana desde Contabilidad. Para medir la actividad económica se utiliza el Total de Ingresos Operacionales, dato que emana desde los informes de Contabilidad.

Para poder gestionar las pérdidas operacionales debemos contar con distintos elementos tales Como:

- Contar con una base de pérdidas por riesgo operacional (BBPP) estructurada
- Definir las fuentes de alimentación
- Asignación de los eventos de pérdidas a las distintas cuentas contables de pérdidas operacionales
- Asignación de las pérdidas operacionales a los procesos formales de la corporación
- Asignación de las pérdidas a las distintas causas y líneas de negocio definidas por Basilea
- Generación de reportes de pérdidas
- Monitorear la evolución de las pérdidas
- Análisis de pérdidas más relevantes

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

3.2. Continuidad de Negocio

Modelo de Gestión de continuidad de negocio en 4 etapas:

1. Análisis de Impacto (BIA), Incluye Ficha del proceso.
2. Análisis de riesgo (RIA)
3. Planes de Continuidad
4. Plan de Prueba, Incluye Planes de Acción

Análisis de Impacto en negocio (BIA)

El análisis de impacto (BIA) comprende el análisis de actividades o procesos y el efecto que una disrupción del negocio pudiera tener sobre ellos. Se establece que el análisis de impacto debe incluir lo siguiente:

- Identificación de actividades que apoyen la provisión de bienes y servicios.
- Evaluación del impacto de no llevar a cabo estas actividades a través del tiempo, estableciendo marcos temporales priorizados para la reanudación de las actividades en el nivel mínimo aceptable especificado, tomando en consideración el tiempo en el cual el impacto de no reanudación de estas pasaría a ser inaceptable.
- Identificación de las dependencias y recursos de apoyo para estas actividades, incluyendo proveedores y otras partes interesadas.

Evaluación de Riesgos de Disrupción (RIA)

Comprende la identificación, evaluación y valoración de los riesgos de los procesos, centrados en aquellos riesgos que podrían afectar a la continuidad del negocio. La cual tiene como objetivos:

- Identificar las amenazas y escenarios de disrupción aplicables sobre los procesos críticos desde el punto de vista de la continuidad de negocio.
- Evaluar el nivel de riesgo asociado a cada escenario de disrupción y recurso crítico identificado.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Identificar los tratamientos acordes a los objetivos de continuidad de negocio y de acuerdo con el apetito al riesgo de la organización

Definición de estrategias, confección planes de acción de continuidad de negocio y pruebas de validación

Para aquellos procesos críticos, se realizarán planes documentados de contingencia (BCP), que permitirán responder a la materialización de los escenarios de contingencia definidos, los que se actualizan al menos anualmente. Asimismo, cuenta con un plan de recuperación ante desastre (DRP) con procedimientos para restaurar y volver a las actividades normales del negocio después de superada la contingencia.

3.3. Analítica

Consiste en el análisis de un gran volumen de datos vinculando los distintos riesgos de los procesos que permitan tener alertas tempranas y fundamenten decisiones a nivel estratégico y operativo con un alcance corporativo que facilite el seguimiento de las acciones comprometidas.

3.4. Experiencia Usuario

Definiremos Experiencia Usuario como la forma en que los usuarios interaccionan con los contenidos y las funcionalidades de la Plataforma, entendiéndose que la vivencia que se produce en este proceso conforma la experiencia de usuario (UX).

La experiencia de usuario (UX) en una herramienta GRC, se puede definir, por tanto, como el proceso de organizar y estructurar los contenidos facilitando su ejecución de manera amigable.

El diseño basado en la experiencia de usuario (UX) resulta de gran importancia en una herramienta GRC conseguir experiencias de usabilidad sencillas e intuitivas, teniendo como

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

objetivo simplificar la gestión de los riesgos de procesos y auditorias interna, informando de forma oportuna a los altos ejecutivos, y con esto permitiendo mejorar la toma de decisiones y focalizar en aquellos procesos que requieren mayor atención.

3.5. Demo

El proveedor debe disponer al Banco una Demo que permita observar, de manera práctica, los servicios ofertados por los oferentes para dar una bajada de los servicios requeridos, permitiendo observar la complejidad de las configuraciones, visualizaciones de las pantallas, registro y gestión de la información de los trabajadores hasta la respectiva reportería y tableros que correspondan al servicio en revisión, para lo cual, se elaboró una guía mínima de lo que será sujeto a evaluación por parte de BancoEstado.

4. Identificación de los Servicios Requeridos

La Gerencia Riesgo Operacional y Tecnológico, junto con la Contraloría requieren una Herramienta que integre y centralice la gestión de los riesgos corporativos, de modo de generar coordinación y trabajo colaborativo entre las distintas líneas y roles, con el fin de contribuir al logro de la estrategia y objetivos corporativos. La herramienta debe manejar la gestión de riesgo de manera práctica, flexible, dinámica y eficiente, incorporando las distintas aristas de información, permitiendo realizar seguimiento a planes de acción comprometidos, que permita la gestión oportuna de acciones, dejando disponible toda la información necesaria en una misma plataforma.

4.1.1. Integración con otros Sistemas / Plataformas / Sitios

El Software debe realizar la integración preferentemente online con sitios, plataformas, sitios, internos como externos en los distintos campos de acción de los servicios de la Gerencia de Riesgos no Financieros y Contraloría como:

- Mapa de Procesos Corporativos

Dicha integración se entenderá con los actuales sistemas / plataformas y/o sitios utilizado por BancoEstado, como así también otras futuras.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Además, debe permitir carga de datos por parte de las áreas auditadas producto de las auditorías y/o observaciones de la Gerencia de Riesgos no Financieros o Contraloría, Gerencias, Subgerencias, Áreas, Departamentos, Unidades, cumplimientos de objetivos, métricas y otras que el Banco requiera (de sus distintos servicios), permitiendo realizar correlaciones entre ellas.

4.1.2. Publicación / Descarga / Emisión archivos y/o documentos

4.1.2.1. Publicación de archivos y/o descarga de archivos

La Plataforma ofertada debe considerar como funcionalidad critica la publicación y/o descarga de archivos en distintos formatos para distintos perfiles como: súper administradores, administradores, usuario trabajador, usuario jefatura entre otros que puedan definirse por la Gerencia Riesgo Operacional y Tecnológico y Contraloría de BancoEstado.

Por lo anterior indicado, la Plataforma debe materializar en la gestión y administración la concreción de las siguientes funcionalidades:

- Publicación de archivos en formatos Word, Excel, Access, SCORM, MP4, WAV, PDF, PPT, entre otros usados y permitidos por el Banco
- La publicación debe ser administrable por el área proveedora de los servicios a los trabajadores y/o áreas, permitiendo la flexibilidad de atribuciones centralizadas por BancoEstado.
- La descarga de los distintos archivos (Word, Excel, Access, SCORM, MP4, WAV, PDF, PPT, entre otros para la obtención de contenido perfilada, según los distintos roles (súper administrador administración, usuario líder, usuario trabajador, entre otros que se requieran)
- La descarga debe dar la opción de guardar el contenido en el dispositivo que esté utilizando el usuario.

4.1.3. Perfiles y Ambientes de Navegación

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

El sistema debe permitir definir grupos de usuarios, respecto de los cuales se definirán distintos perfiles de acceso, de acuerdo a los roles de usuarios y las funcionalidades de la plataforma:

- Súper-administrador, perfil que configura y parametriza la plataforma a nivel Multiempresa, División, Gerencia, Subgerencia, Área, Departamento y/o Unidad, permitiéndole administrar, gestionar y obtener una mirada macro y específica de los trabajadores o responsables definidos.
- Perfil Administrador debe contener los mismos permisos del súper administrador, acotados de una Empresa a nivel de Gerencias, Subgerencia, Área y/o Unidad.
- Perfil Jefatura y/o Líder, este perfil debe permitir la administración y gestión de un grupo determinado de trabajadores que se encuentren bajo su dependencia directa.
- El perfil del Trabajador debe permitir la visualización de su perfil como trabajador y antecedentes relevantes asociados a los distintos módulos ofertados.
- Perfil Gestor, es el trabajador encargado de interactuar con la Gerencia de Riesgos no Financieros o Contraloría producto de las observaciones y planes de acción acordados.
- En lo que respecta a los ambientes de Navegación el software debe permitir que se formen ambientes colaborativos, estos entendidos como un espacio donde se puedan realizar vinculaciones cruzadas y/o relacionadas de los distintos servicios a proveer con distintas instancias de visualización.

4.1.4. Experiencia Usuario

La herramienta ofertada debe proporcionar un ambiente que entregue una buena experiencia de usuario con los siguientes orientados en las siguientes líneas:

- Diseño que ofrezca experiencias personalizadas y relevantes a los usuarios, involucrando todos los elementos de imagen, diseño e identidad que provocan fuertes emociones de apreciación y atracción por los usuarios.
- Altos estándares de usabilidad y que les permita acceder a su información de manera fidedigna y clara con el uso de interfaz de manera sencilla desde los

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

distintos procesos Banco, hasta el nivel de satisfacción que provoca el diseño, tanto en la personalización como en su globalidad.

- Navegabilidad fácil, flexible rápida para desplazarse por los contenidos de la Plataforma.
- Medición de la experiencia de usuario correspondiente a medir el nivel de satisfacción total de usuarios, por medio de una encuesta u otra herramienta.
- Plataforma responsiva de contenido personalizado y auto - ajustable.
- Compatibilidad con todos los navegadores, especialmente con los navegadores estándar definidos por el Banco, a la fecha debiera considerar compatibilidad con Google Chrome y Microsoft Edge +, sin perjuicio, de que dichos estándares son susceptibles de ser modificados por el Banco. Para el caso de los usuarios que naveguen fuera de la red banco, se sugiere que el proveedor indique algún estándar mínimo.
- En el caso que la plataforma genere documentos con formatos de uso común (por ejemplo: Word, Excel, PDF), estos se deben ajustar a las versiones estándar utilizadas por el Banco, sin perjuicio de que estas versiones pueden ser cambiadas por el Banco.

4.1.5. Directorio Activo

Se requiere que la herramienta se integre con el Directorio Activo de la Corporación, para el ingreso en cada uno de los módulos ofertados, según perfilamiento, permisos y políticas de acceso vigentes.

4.1.6. Reportería / Dashboard / Tableros

Este ítem requiere una solución que permita la generación de informes por medio de archivos o su visualización online, bajo las siguientes condiciones:

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Información automatizada y con una configuración flexible, permitiendo a los usuarios de la Corporación BancoEstado (según atribuciones) extraer información de manera autónoma.
- Visualización por medio de Dashboard y/o Tableros que permita a los usuarios (súper - administradores, administradores y algún otro perfil que se defina) ver gráficos bidimensionales y tridimensionales, así como centrarse en determinadas áreas de interés para realizar un análisis más detallado.
- Servicio de reportabilidad y seguimiento de los trabajadores con fácil acceso y visualización personalizada desde las áreas usuarias y perfiles según corresponda.
- Debe ser factible que las jefaturas tengan acceso a los reportes y estados de avance de sus equipos de trabajo.
- Reportes exportables a formato Excel, PDF y/o PPT, para gestión, análisis y también en formatos visuales (gráficos) u otra herramienta de BI utilizada por el Banco, que permitan su presentación a la Corporación, Gerencias, Subgerencia, Área y/o Unidad o en su defecto resúmenes individuales, según el perfil que requiera el reporte.

4.1.7. Tracking

La herramienta ofertada debe contar con un instrumento de seguimiento de navegabilidad de los usuarios que permita individualizar participación en actividades, tiempo de navegación, dispositivo de navegación (dispositivo móvil, Tablet. Notebook o PC) y ámbito de módulo de navegación.

4.1.8. Soporte

El Servicio de soporte ofertado por el proponente debe estar orientado a resolver los problemas que puedan presentárseles a los usuarios durante la vigencia del contrato en sus distintos niveles (Súper - administradores, Administradores y algún otro perfil que la Gerencia

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Riesgo Operacional y Tecnológico y/o Contraloría señale), por lo que se diferenciará en bajo los siguientes puntos:

4.1.8.1. Soporte Funcional / Configuración (Perfil Administrador)

- Configuración los parámetros generales del Portal (set up inicial y configuración de layout.).
- En la optimización del uso de la plataforma en lo que respecta a la oportunidad en las configuraciones y parametrizaciones de las distintas funcionalidades de Administración y/o gestión para el cumplimiento de sus objetivos, en cada uno de los módulos a ofertar.
- Todos los componentes de este servicio deberán ser en el idioma español. Esto incluye para la entrega de tutoriales, manuales operativos de usuario, capacitaciones, ayuda en línea, notificaciones por correo electrónico, capacitaciones y todos los materiales entregados a BancoEstado, parametrizaciones, presentaciones, personalizaciones, configuración de los módulos, títulos de los módulos, pasantías o acompañamientos, soporte, como también todas las instancias de comunicación con el Banco, considerando distintos canales.
- Soporte a las áreas usuarias del Corporativo BancoEstado, en los procesos de administración de cada uno de los módulos ofertados.
- El oferente debe prestar soporte para el desarrollo de nuevos reportes requeridos en todos los módulos solicitados.
- La empresa debe prestar soporte para el desarrollo de nuevos reportes en todos los módulos requeridos.
- Se requiere Soporte a usuarios 5x9 (Telefónico, correo electrónico o chat).

4.1.8.2. Soporte Rol General del Usuario

Soporte de auto atención para rol general de trabajador, según corresponda a los módulos:

- Riesgo Operacional
- Continuidad de Negocio
- Auditoria Interna.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Y también problemas que se presenten a los usuarios, como por ejemplo:
    - ✓ Resolver bloqueo o claves de ingreso, para los usuarios.
    - ✓ Subida o descargas de archivos.
    - ✓ No carga curso,
    - ✓ Visualización de perfil,
    - ✓ Navegación de cursos, etc,
- Entrega de tutoriales, manuales operativos de usuario, ayuda en línea y/o correo electrónico.
- Soporte telefónico.
- Se requiere Soporte a usuarios 5x9 (Telefónico, correo electrónico o chat).

4.2. Servicios Específicos

La Plataforma ofertada debe disponer de funcionalidades que aborden cada una de los requerimientos específicos que se detallan a continuación:

4.2.1. Riesgo Operacional

Este módulo debe permitir la administración y gestión de los riesgos según la metodología definida por Riesgo Operacional.

4.2.1.1. Registro de Matrices de Riesgo

- Registrar matrices de riesgo operacional con los atributos mínimos como Proceso, Responsable Proceso, Riesgos, los riegos debe contener los siguientes atributos:
    - ✓ Objetivos Corporativos asociados
    - ✓ Etapas o Actividades
    - ✓ Riesgo de Pérdida
    - ✓ Tipos de pérdida Basilea
    - ✓ Factor de Riesgo (Librería o Tipología)

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Factor de Riesgo Especifico
- ✓ Controles y Factores de evaluación de diseño
- ✓ Impacto Los valores pueden ser (1) Bajo, (2) Medio Bajo, (3) Medio, (4) Medio Alto y (5) Alto, en alguno de estos ámbitos Clientes, Monetarios, Reputacional, Normativo Proceso.
- ✓ Probabilidad. Los valores pueden ser (1) Muy poco probable, (2) Poco Probable, (3) Ocasional, (4) Frecuente y (5) Muy Frecuente.
- ✓ Efectividad del Control. El valor puede ser (1) Deficiente, (2) Regular, (3) Suficiente, (4) Bueno y (5) Óptimo.
- ✓ Riesgo Inherente, se calcula Impacto x Probabilidad, donde el resultado puede ser (1) Bajo, (2) Medio Bajo, (3) Medio, (4) Medio Alto y (5) Alto. En el caso particular de los riesgos de Alto Impacto (5) y baja probabilidad (1) se decide graduar éste riesgo como (4) Medio Alto.
- ✓ Riesgo Residual (Nivel de Riesgo Inherente/Nivel de Efectividad de control) ✓ Requiere Revisión del Control. El valor es Si o No.
- ✓ Requiere Indicador (KRI). El valor es Si o No.
- ✓ Requiere Plan de Acción. El valor es Si o No

4.2.1.2. Gestión de los Riesgos

- Cuando se ingresa una matriz, la herramienta debe enviar email al responsable del proceso, para su correspondiente aprobación.
- El responsable del proceso debe autorizar la matriz a través del sistema.
- El responsable del proceso debe tener la facultad de poder editar los riesgos de las matrices bajo su responsabilidad y tener la facultad de agregar nuevos riegos.
- La herramienta debe generar catálogo de riesgo en base a las matrices cargadas.
- La herramienta debe generar catálogo de controles en base a las matrices cargadas.
- La herramienta debe permitir cargar listas de procesos, con su responsable, y sub responsable y cargar los riesgos por procesos.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- La herramienta debe realizar automáticamente los cálculos de Riesgo Inherentes y Riesgo Residual (Según se indica en este documento en el punto 3.1. definiciones de Riesgo Operacional).
- La herramienta debe permitir realizar búsquedas de información por distintos criterios tales como Procesos, Riesgo Inherente (Altos, Medios Altos), Riesgo Residual (Altos, Medios Altos), entre otros.
- Debe permitir automatizar de forma manual.
- La herramienta debe ser adaptable a las actuales planillas que utiliza la Gerencia de Riesgos no Financieros, o bien los cambios deben ser menores.

4.2.1.3. Gestión de KRI (indicadores claves de Riesgo)

- La herramienta debe generar un catálogo de KRI, desde las matrices cargadas.
- En caso que se requiera, la herramienta debe permitir asociar KRI (Indicadores Claves de Riesgo) a la matriz. El indicador tiene los siguientes atributos,

  - ✓ Etapas o Actividades
  - ✓ Riesgo de Pérdida
  - ✓ Tipos de pérdida Basilea
  - ✓ Factor de Riesgo
  - ✓ Factor de Riesgo Especifico
  - ✓ Indicadores
  - ✓ Criterios de Aceptación.
  - ✓ Fecha a partir de la cual se comienza a medir.
  - ✓ Responsable de la entrega de la información.

- El responsable del proceso debe tener la facultad de registrar sus indicadores.
- Si el indicador no ha sido registrado, el sistema debe escalar la solicitud de éste a su jefatura, a través de un correo.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Si un indicador está fuera de umbral, fuera de los criterios de aceptación, por un periodo de tiempo (actualmente son 3 meses seguidos), el sistema debe solicitar el ingreso de un plan de acción.

4.2.1.4. Gestión Plan de Acción

- La herramienta debe permitir registro de Planes de Acción.
- Los campos que considera un Plan de Acción ID, Área específica, Jefatura, Responsable Seguimiento, Responsable Ejecución, Planes de acción, Nivel de Riesgo (RR), Proceso / Servicio Asociado, Informe de Riesgo/ Matriz de Riesgo/ KRI fuera de umbral / Prueba continuidad / Monitoreo control, Fecha de ingreso, Fecha anterior 2da Reprogramación, Fecha anterior 1era Reprogramación , Fecha comprometida, Fecha máxima de entrega, Fecha de finalización real, % de avance actual, % de avance esperado, Descripción del avance.
- La herramienta debe de exigir Planes de Acción cuando sea requerido. En la metodología Banco, exigirá la implementación de planes de acción en las siguientes situaciones:
    - ✓ A partir de la identificación de desviaciones en los indicadores de riesgo definidos, es decir, resultados excedidos en los criterios de aceptación o límites por un periodo de tres meses consecutivos, se debe analizar la necesidad de la definición e implementación de planes de acción en esta circunstancia tomando en cuenta que la desviación puede deberse a una situación puntual versus una que presente causas raíces.
    - ✓ Si la certificación de los controles de los riesgos inherentes Alto y Medio Alto no fueron satisfactorios y la efectividad en el diseño y/o su ejecución resultó poco efectivo, se deberán comprometer planes de acción para su mejora.
    - ✓ Al confeccionar la matriz de riesgo definitiva de cada proceso que contenga riesgos residuales que resulten significativos, es decir, Altos o Medio Altos, se deberán comprometer planes de acción con una fecha límite de compromiso. Pueden existir excepciones.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Se deja la posibilidad de que por análisis de riesgos presentados ya sea por el analista de Riesgos o a solicitud del responsable de proceso, se soliciten planes de acción para aquellos riesgos residuales clasificados bajos o moderados, los cuales una vez que han sido comprometidos, deberán regirse por los monitoreos establecidos.

- Cuando se cumple una fecha de compromiso de un plan de acción el sistema debe permitir generar alertas.
- La herramienta debe contar con la facultad de realizar seguimientos a los planes de acción cargados.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Matriz de Riesgo Operacional

Proceso: Administración de Cuentas Corrientes en Bancos Corresponsales
Responsable: Marcelo Henriquez Isla

								IMPACTOS											
															Alto	Medio			
N°	Etapas o Actividades	Riesgos de Pérdida	Tipos de Pérdida Basilea	Factor de Riesgo	Factor de Riesgo Específico	Controles identificados	Impacto	Monetario	Clientes	Reputacional	Normativo	Procesos	Probabilidad	Efectividad del control	Riesgo Inherente	Riesgo Residual	Requiere revisión de control	Requiere Indicador	Requiere plan de acción
1	Evaluación para la apertura de Cuenta Corriente	Multas_y_Sanciones	Ejecución_Entrega_Y_Gestión_De_Procesos	Incumplimiento_de_políticas_normas_leyes_o_regulaciones	Que debido a una mala evaluación se realice la apertura de una cuenta corriente con un Banco Corresponsal que no cumple la normativa exigida y esto exponga al Banco a incumplimiento de Normas y Políticas internas.	Para asegurar la correcta apertura de las cuentas, se realizan las siguientes validaciones: 1.- Gerencia de Negocios Internacionales: evalúa ..... 2.- Riesgo Crédito: A través de la ..... 3.- Compliance: Realiza el proceso de ..... 4.- Comité de Negocios Financieros: es quien realiza.....	Normativo	1 Bajo	1 Bajo	1 Bajo	2 Medio Bajo	1 Bajo	2 Poco Probable	3 Suficiente	Medio bajo	Bajo	NO	NO	NO

KRI

Proceso: Administración de Cuentas Corrientes en Bancos Corresponsales
Responsable del Proceso: Marcelo Henriquez Isla

N°	Etapas o Actividades	Riesgos de Pérdida	Tipos de Pérdida Basilea	Factor de Riesgo	Factor de Riesgo Específico	Indicadores	Criterios de Aceptación	Fecha a partir de la cual se comienza a medir	Responsable de la entrega de la información
3	Proceso de Conciliación Bancaria de movimientos en cuentas con corresponsales	Multas_y_Sanciones	Ejecución_Entrega_Y_Gestión_De_Procesos	Retrasos_importantes	Que no se realicen las conciliaciones bancarias	% de partidas pendientes sin conciliar	<0,1	Se mide desde el año 2019	NNN
4	Proceso de Conciliación Bancaria de movimientos en cuentas con corresponsales	Costos_adicionales_del_proceso	Ejecución_Entrega_Y_Gestión_De_Procesos	Retrasos_importantes	Que se retrasen los análisis				

Plan de Acción

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Proceso: Administración de Cuentas Corrientes en Bancos Corresponsales
Responsable del Proceso: Marcelo Henriquez Isla

N°	Etapas o Actividades	Riesgos de Pérdida	Tipos de Pérdida Basilea	Factor de Riesgo	Factor de Riesgo Específico	Controles identificados	Plan de acción	Fecha Implementación	Responsable
2									
3									
4									

Escala Impacto

ESCALA IMPACTO					
Impacto	Monetario	Procesos	Reputacional	Normativo	Clientes
1. Bajo	Hasta un 0,01% del ingreso operacional de la institución. (Ref. MM$	No afecta otras funciones o procesos del Banco Estado.	Impacto no relevante para el proceso de negocio; no afecta la reputación de Banco Estado.	Impacto no relevante para el proceso de negocio; sin impactos normativos.	La materialización del evento no afecta a los clientes.
2. Medio Bajo	Hasta un 0,03% del ingreso operacional de la institución. (Ref. MM$ 488)	Afecta a otras funciones o procesos, sin interrumpirlo (p.ej. degradación en el nivel de servicio).	La interrupción del proceso es percibida sólo al interior del Banco o su conocimiento es muy restringido.	El incidente es de conocimiento por el regulador y/o organismos normativos, podria implicar la solicitud de información al Banco en relación a los procesos y clientes que se han visto afectados.	El evento materializado afectará a un grupo reducido de clientes (menos de 5.000 como referencia). O afectará a menos del 1% de los clientes mayoristas, pero que ninguno de estos sea VIP
3. Medio	Hasta un 0,06% del ingreso operacional de la institución. (Ref. MM$ 975)	Afecta a otras funciones o procesos, sin interrumpirlo, pero si se prolonga en el en el tiempo podría impactar en el cumplimiento de los ANS internos.	El incidente se divulga en medios de comunicación no masivos y/o en las redes sociales, entre 100 y 500 menciones, a una velocidad entre 51 a 100 por hora. Es percibido principalmente por los clientes del Banco.	El incidente, y los impactos que éste genere, deberán ser notificados a el regulador y/o organismos normativos; puede provocar sanciones u observaciones.	El evento materializado afectará a una cantidad no muy significativa de clientes (entre 5.000 y 25.000). O afectará a más del 1% de clientes mayoristas o al menos 1 cliente VIP
4. Medio Alto	Hasta un 0,09% del ingreso operacional de la institución. (Ref. MM$ 1.463)	Afecta otras funciones o procesos de forma inmediata, impactando en el cumplimiento de los ANS internos y/o terceras partes involucradas.	El incidente es difundido en medios especificos de denuncia y en las redes sociales, más de 501 menciones a una velocidad de más de 100 menciones por hora. Es percibido por los otros actores de la industria financiera.	El incidente conllevará a una investigación formal del regulador y/o organismos normativos y multas, con alta visibilidad y divulgación a público, alta implicación de directivos del Banco durante el proceso de la investigación.	El evento materializado es critico para los clientes y afectará a un número significativo de ellos (entre 5.000 y 25.000). O afectará a entre el 1% y el 10% de clientes mayoristas o hasta de 3 clientes VIP
5. Alto	Más de un 0,09%	Afecta significativamente a otras funciones o procesos de forma inmediata, implicando la interrupción de los procesos que se ven impactados.	El incidente es difundido ampliamente en los diferentes medios de comunicación masiva a nivel nacional. Podría conducir a un daño significativo en la reputación de Banco Estado.	La situación obligará al pronunciamiento público de parte del regulador y/o organismos normativos en relación al incidente, pudiendo verse comprometida la calificación del Banco.	El evento materializado afectará masivamente a los clientes del Banco (sobre 25.000) y será muy sensible para ellos. O afectará a más del 10% de clientes mayoristas y más de 3 clientes VIP

Escala Probabilidad

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Probabilidad	Ocurrencia
1 Muy poco probable	No existen antecedentes acerca de la materialización del riesgo en el pasado y no se espera que ocurra en el futuro o la amenaza es muy poco probable que se produzca u ocurra 1 vez cada 10 años
2 Poco Probable	El evento sólo ocurrirá en circunstancias excepcionales, o como resultado de una combinación de eventos inusuales o la amenaza es poco probable que se produzca u ocurra rara vez, a lo más 1 vez
3. Ocasional	Dada la naturaleza del riesgo es razonable esperar su materialización en el corto plazo (un año) o la amenaza es algo probable que se produzca u ocurra ocasionalmente (una vez en el año) o menos del 2% de los casos (transacciones, operaciones).
4. Frecuente	Se espera que el riesgo se materialice en reiteradas ocasiones en el corto plazo (un año) o la amenaza es muy probable que se produzca u ocurra trimestralmente o entre el 2% y el 10% de los casos (transacciones, operaciones).
5. Muy frecuente	Se espera que el riesgo se materialice en la mayoría de las situaciones en que se encuentra presente o amenaza es casi seguro que se produzca u ocurra por lo menos una vez al mes o sobre el 10% de los casos (transacciones, operaciones).

Evaluación de Control

Evaluación del Control	Oportunidad del Control	Alcance del Control	Automatización	Formalización / Evidencia	Para Continuidad de Negocios
1. Deficiente	No existe, o No se ejecuta, o Correctivo	Cobertura parcial	Manual sin segregación de funciones	No está formalizado y no tiene registros de su ejecución	Para todas las áreas **menos Sucursales**. • No existe plan de Continuidad o • Existe Plan de continuidad, pero no está formalizado o • Existe Plan de continuidad, pero no está actualizado Para **sucursales solamente**: • Se han realizado pruebas reales con resultado promedio de satisfacción < = 50% de las sucursales a probar según plan estratégico para el año o Plan de continuidad no ha sido probado.
2. Regular	Detectivo	Cobertura parcial	Manual con segregación de funciones	No está formalizado, pero tiene registro de su ejecución	Para todas las áreas **menos Sucursales**. •Existe Plan de continuidad pero no se han realizado pruebas para factor de riesgo específico, de acuerdo a la periodicidad requerida o •Existe Plan de continuidad pero el resultado de la prueba para factor de riesgo específico es INSUFICENTE, de acuerdo al nivel de madurez definido o •Existe sólo un Plan Comunicacional formalizado y probado. Para **sucursales solamente:** • Se han realizado pruebas reales con resultado promedio de satisfacción > 50% y < = 60% de las sucursales a probar según plan estratégico para el año.
3. Suficiente	Detectivo	Abarca todas las operaciones	Control manual o semiautomático con contraposición de funciones	Está formalizado y tiene registro de su ejecución	Para todas las áreas **menos Sucursales**. •Existe Plan de Continuidad y se han realizado pruebas de escritorio (conocimiento, secuencias de Para **sucursales solamente**: • Se han realizado pruebas reales con resultado promedio de satisfacción > 60% y < = 70% de las sucursales a probar según plan estratégico para el año.
4. Bueno	Preventivo	Abarca todas las operaciones	Semiautomático con contraposición de funciones	Está formalizado y difundido, tiene registro de su ejecución	Para todas las áreas **menos Sucursales**. •Existe Plan de Continuidad y se han realizado pruebas de simulación para factor de riesgo específico con Para **sucursales solamente**: • Se han realizado pruebas reales con resultado promedio de satisfacción > 70% y < 80% de las sucursales a probar según plan estratégico para el año.
5. Óptimo	Preventivo	Abarca todas las operaciones	Control automático con monitoreo	Está formalizado y difundido, tiene registro de su ejecución y se hace monitoreo sobre su desempeño	Para todas las áreas **menos Sucursales**. •Existe Plan de Continuidad y se han realizado pruebas reales para factor de riesgo específico con resultado Para **sucursales solamente:** • Se han realizado pruebas reales con resultado promedio SUFICIENTE > = 80% en todas las sucursales

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

4.2.2. Continuidad de Negocio

4.2.2.1. Registro de BIA/RIA

- La herramienta debe permitir el registro de los Análisis de Impacto de Negocio (BIA) (Formato indicado en el punto Instrumentos). Este análisis debe contener,

  - ✓ Identificación de actividades que apoyen la provisión de bienes y servicios.
  - ✓ Evaluación del impacto de no llevar a cabo estas actividades a través del tiempo, estableciendo marcos temporales priorizados para la reanudación de las actividades en el nivel mínimo aceptable especificado, tomando en consideración el tiempo en el cual el impacto de no reanudación de estas pasaría a ser inaceptable. (Escala de Impacto indicado en el punto Instrumentos).
  - ✓ Identificación de las dependencias y recursos de apoyo para estas actividades, incluyendo proveedores y otras partes interesadas.

- La herramienta debe permitir cargar Análisis de Impacto BIA. (Ficha de Evaluación de Impacto BIA-RIA indicado en el punto Instrumentos).
- Considerar la siguiente información en el relevamiento de información del proceso, donde el responsable del proceso identifica los recursos críticos para la ejecución del proceso y otros requerimientos para operar en contingencia y llevar a cabo las actividades de recuperación. Por otro lado, Analista de Continuidad de Negocio llena Ficha del proceso que contiene información detallada en relación a las personas, infraestructura, sistemas, proveedores y otros datos. (Incluido en el punto Instrumentos).
- Análisis de Impacto por Escenario y Ámbito. El responsable de proceso en conjunto con Unidad de Continuidad de Negocios

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Evalúan la criticidad de la indisponibilidad de los recursos asociados a la ejecución del proceso analizado para todos los escenarios de riesgo; considerando los diferentes ámbitos.
- ✓ Determinan el nivel de criticidad de la interrupción del proceso conforme a la duración de la contingencia.

- El Analista de Continuidad de Negocio. Completa Ficha de evaluación de impacto.
- La herramienta debe permitir cargar escenarios de riesgo.

Escenarios de Riesgo

Ausencia masiva del personal

Indisponibilidad parcial o pérdida del personal clave

Indisponibilidad de un edificio o conjunto de edificios

Indisponibilidad de servicios prestados por proveedores

Indisponibilidad de una aplicación / servicio TI crítico para la ejecución del proceso

Indisponibilidad masiva de aplicaciones/ servicios TI / comunicaciones Ataque de Ciberseguridad.

- La herramienta debe permitir cargar escenarios de disrupción.

Escenarios de Disrupción

Escenario
Indisponibilidad parcial o pérdida del personal clave
Indisponibilidad de un edificio o conjunto de edificios
Indisponibilidad o destrucción de una Sucursal o conjunto de Sucursales
Imposibilidad de restauración inmediata de servicios básicos
Indisponibilidad de servicios prestados por proveedores
Indisponibilidad del suministro de efectivo

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Indisponibilidad de una aplicación / servicio TI crítico para la ejecución del proceso
Indisponibilidad masiva de aplicaciones/ servicios TI / comunicaciones
Ataque de Ciberseguridad

- Existen 6 escalas de horario que definen el nivel de criticidad de interrupción del proceso.
- Determinación del Impacto Final por escenario.
- La herramienta debe permitir cargar Evaluación de Riesgo de Disrupción (RIA). Ficha de Evaluación del impacto de los riesgos de disrupción. El Analista de Continuidad de Negocio, verifica los escenarios que resulten críticos por continuidad de negocio en la evaluación de impacto del negocio (BIA). Solo para escenarios de mayor impacto hasta las 24 hrs. y con valor “MEDIO ALTO” o “ALTO” (de acuerdo al apetito de riesgo definido), se realizará el análisis de riesgos (RIA).
- La herramienta debe permitir relacionar BIA con RIA.
- Debe ser posible cargar planes documentados de contingencia (BCP), solo para proceso críticos, los cuales que permiten responder a la materialización de los escenarios de contingencia definidos, los cuales se actualizan al menos anualmente.
- Además, debe ser posible cargar Planes de recuperación de desastre (DRP), el cual contiene procedimientos para restaurar y volver a las actividades normales del negocio una vez superada la contingencia.
- Deseable que la herramienta posea un módulo de prueba (BCP/DRP).
- Que sea posible cargar un catálogo de BCP en el sistema, simple de manejar. Tipología actual. (Escenario de Disrupción, Nombre de archivo base confección BCP, Contenido documento).
- La herramienta debe permitir el registro y carga de los Análisis de Impacto de Negocio (BIA) (Formato BIA). Este análisis debe contener:

  - ✓ Nombre del Proceso.
  - ✓ Escenarios de disrupción.
  - ✓ Impacto en el proceso en los distintos ámbitos.
  - ✓ Escalas de horario, que definen el nivel de criticidad de la interrupción del proceso.
  - ✓ Determinación del Impacto Final del proceso por escenario.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- En el BIA, el responsable de proceso en conjunto con Unidad de Continuidad de Negocios

  - ✓ Evalúan la criticidad de la indisponibilidad de los recursos asociados a la ejecución del proceso analizado para todos los escenarios de riesgo; considerando los diferentes ámbitos. ·
  - ✓ Determinan el nivel de criticidad de la interrupción del proceso conforme a la duración de la contingencia.

- Para todos los escenarios que resulten críticos por continuidad de negocios y con un impacto mayor a las 24 horas. Es decir, en el análisis final del BIA se obtenga como resultado “Medio Alto” o “Alto”, la herramienta debe permitir cargar la Evaluación de Riesgo (RIA).
- La Evaluación de Riesgo a cargar debe contener información más específica identificando los siguientes puntos:

  - ✓ Etapas o actividades.
  - ✓ Factores de riesgo.
  - ✓ Factores de riesgo específicos.
  - ✓ Controles identificados.
  - ✓ Tipo de impacto y mayor impacto a las 24 horas (datos extraídos desde el BIA).
  - ✓ Probabilidad y Evaluación del control.
  - ✓ Respuesta al riesgo presentado.
  - ✓ Otros.

- La herramienta debe permitir relacionar datos entre la Ficha del proceso, BIA y RIA.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Instrumentos

Escala Impacto

ESCALA IMPACTO					
Impacto	Monetario	Procesos	Reputacional	Normativo	Clientes
1. Bajo	Hasta un 0,01% del ingreso operacional de la institución. (Ref. MM$	No afecta otras funciones o procesos del Banco Estado.	Impacto no relevante para el proceso de negocio; no afecta la reputación de Banco Estado.	Impacto no relevante para el proceso de negocio; sin impactos normativos.	La materialización del evento no afecta a los clientes.
2. Medio Bajo	Hasta un 0,03% del ingreso operacional de la institución. (Ref. MM$ 488)	Afecta a otras funciones o procesos, sin interrumpirlo (p.ej. degradación en el nivel de servicio).	La interrupción del proceso es percibida sólo al interior del Banco o su conocimiento es muy restringido.	El incidente es de conocimiento por el regulador y/o organismos normativos, podría implicar la solicitud de información al Banco en relación a los procesos y clientes que se han visto afectados.	El evento materializado afectará a un grupo reducido de clientes (menos de 5.000 como referencia). O afectará a menos del 1% de los clientes mayoristas, pero que ninguno de estos sea VIP
3. Medio	Hasta un 0,06% del ingreso operacional de la institución. (Ref. MM$ 975)	Afecta a otras funciones o procesos, sin interrumpirlo, pero si se prolonga en el en el tiempo podría impactar en el cumplimiento de los ANS internos.	El incidente se divulga en medios de comunicación no masivos y/o en las redes sociales, entre 100 y 500 menciones, a una velocidad entre 51 a 100 por hora. Es percibido principalmente por los clientes del Banco.	El incidente, y los impactos que éste genere, deberán ser notificados a el regulador y/o organismos normativos; puede provocar sanciones u observaciones.	El evento materializado afectará a una cantidad no muy significativa de clientes (entre 5.000 y 25.000). O afectará a más del 1% de clientes mayoristas o al menos 1 cliente VIP
4. Medio Alto	Hasta un 0,09% del ingreso operacional de la institución. (Ref. MM$ 1.463)	Afecta otras funciones o procesos de forma inmediata, impactando en el cumplimiento de los ANS internos y/o terceras partes involucradas.	El incidente es difundido en medios específicos de denuncia y en las redes sociales, más de 501 menciones a una velocidad de más de 100 menciones por hora. Es percibido por los otros actores de la industria financiera.	El incidente conllevará a una investigación formal del regulador y/o organismos normativos y multas, con alta visibilidad y divulgación a público, alta implicación de directivos del Banco durante el proceso de la investigación.	El evento materializado es critico para los clientes y afectará a un número significativo de ellos (entre 5.000 y 25.000). O afectará a entre el 1% y el 10% de clientes mayoristas o hasta de 3 clientes VIP
5. Alto	Más de un 0,09%	Afecta significativamente a otras funciones o procesos de forma inmediata, implicando la interrupción de los procesos que se ven impactados.	El incidente es difundido ampliamente en los diferentes medios de comunicación masiva a nivel nacional. Podría conducir a un daño significativo en la reputación de Banco Estado.	La situación obligará al pronunciamiento público de parte del regulador y/o organismos normativos en relación al incidente, pudiendo verse comprometida la calificación del Banco.	El evento materializado afectará masivamente a los clientes del Banco (sobre 25.000) y será muy sensible para ellos. O afectará a más del 10% de clientes mayoristas y más de 3 clientes VIP

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Escala Probabilidad

Probabilidad	Ocurrencia
1 Muy poco probable	No existen antecedentes acerca de la materialización del riesgo en el pasado y no se espera que ocurra en el futuro o la amenaza es muy poco probable que se produzca u ocurra 1 vez cada 10 años
2 Poco Probable	El evento sólo ocurrirá en circunstancias excepcionales, o como resultado de una combinación de eventos inusuales o la amenaza es poco probable que se produzca u ocurra rara vez, a lo más 1 vez
3. Ocasional	Dada la naturaleza del riesgo es razonable esperar su materialización en el corto plazo (un año) o la amenaza es algo probable que se produzca u ocurra ocasionalmente (una vez en el año) o menos del 2% de los casos (transacciones, operaciones).
4. Frecuente	Se espera que el riesgo se materialice en reiteradas ocasiones en el corto plazo (un año) o la amenaza es muy probable que se produzca u ocurra trimestralmente o entre el 2% y el 10% de los casos (transacciones, operaciones).
5. Muy frecuente	Se espera que el riesgo se materialice en la mayoría de las situaciones en que se encuentra presente o amenaza es casi seguro que se produzca u ocurra por lo menos una vez al mes o sobre el 10% de los casos (transacciones, operaciones).

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Evaluación de Control

Evaluación del Control	Oportunidad del Control	Alcance del Control	Automatización	Formalización / Evidencia	Para Continuidad de Negocios
1. Deficiente	No existe, o No se ejecuta, o Correctivo	Cobertura parcial	Manual sin segregación de funciones	No está formalizado y no tiene registros de su ejecución	Para todas las áreas **menos Sucursales**. • No existe plan de Continuidad o • Existe Plan de continuidad, pero no está formalizado o • Existe Plan de continuidad, pero no está actualizado Para **sucursales solamente**: • Se han realizado pruebas reales con resultado promedio de satisfacción < = 50% de las sucursales a probar según plan estratégico para el año o Plan de continuidad no ha sido probado.
2. Regular	Detectivo	Cobertura parcial	Manual con segregación de funciones	No está formalizado, pero tiene registro de su ejecución	Para todas las áreas **menos Sucursales**. •Existe Plan de continuidad pero no se han realizado pruebas para factor de riesgo específico, de acuerdo a la periodicidad requerida o •Existe Plan de continuidad pero el resultado de la prueba para factor de riesgo específico es INSUFICENTE, de acuerdo al nivel de madurez definido o •Existe sólo un Plan Comunicacional formalizado y probado. Para **sucursales solamente:** • Se han realizado pruebas reales con resultado promedio de satisfacción > 50% y < = 60% de las sucursales a probar según plan estratégico para el año.
3. Suficiente	Detectivo	Abarca todas las operaciones	Control manual o semiautomático con contraposición de funciones	Está formalizado y tiene registro de su ejecución	Para todas las áreas **menos Sucursales**. •Existe Plan de Continuidad y se han realizado pruebas de escritorio (conocimiento, secuencias de Para **sucursales solamente**: • Se han realizado pruebas reales con resultado promedio de satisfacción > 60% y < = 70% de las sucursales a probar según plan estratégico para el año.
4. Bueno	Preventivo	Abarca todas las operaciones	Semiautomático con contraposición de funciones	Está formalizado y difundido, tiene registro de su ejecución	Para todas las áreas **menos Sucursales**. •Existe Plan de Continuidad y se han realizado pruebas de simulación para factor de riesgo específico con Para **sucursales solamente**: • Se han realizado pruebas reales con resultado promedio de satisfacción > 70% y < 80% de las sucursales a probar según plan estratégico para el año.
5. Óptimo	Preventivo	Abarca todas las operaciones	Control automático con monitoreo	Está formalizado y difundido, tiene registro de su ejecución y se hace monitoreo sobre su desempeño	Para todas las áreas **menos Sucursales**. •Existe Plan de Continuidad y se han realizado pruebas reales para factor de riesgo específico con resultado Para **sucursales solamente:** • Se han realizado pruebas reales con resultado promedio SUFICIENTE > = 80% en todas las sucursales

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Ficha de Proceso

FICHA DE PROCESOS	
Fecha en que se revisa la ficha	
Afecta Cadena de Pago	
Nombre del Proceso	
Responsable de Proceso y su cargo	
Objetivo y Alcance	
Canal en donde se desarrolla el proceso	
Unidades de Negocios donde se desarrolla el proceso	
Ubicación / Locación	
Nombre del Aplicativos/sistemas/plataforma	
Nombre del Aplicativos/sistemas/plataforma	
Nombre del Aplicativos/sistemas/plataforma	
Nombre del Aplicativos/sistemas/plataforma	
Nombre del Aplicativos/sistemas/plataforma	
Proveedor	
Fechas y horarios criticos del proceso	
Datos transaccionales	
Montos transados (Promedio mensual)	
Cantidad de transacciones (Promedio mensual)	
Pérdidas operacionales (Promedio mensual)	
Cantidad de clientes involucrados (Promedio mensual)	

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Evaluación de impacto BIA

Instrucciones de llenado:

Escenarios a evaluar 5

Se debe realizar una evaluación por cada ámbito: **Monetario, Procesos, Reputacional, Clientes, Normativo.** 5

Cada ámbito tiene su propia **escala de cinco niveles**

Nombre de Procesos	Escenarios de disrupción	Monetario					
		< 1 HORA	ENTRE 1 Y 2 HORAS	ENTRE 2 Y 6 HORAS	ENTRE 6 Y 24 HORAS	ENTRE 24 Y 36 HORAS	> 36 HORAS
Nombre proceso	Indisponibilidad **parcial del personal**	Bajo	Medio Bajo	Medio	Medio alto	Alto	Alto
Nombre proceso	Indisponibilidad masiva del personal	Critico por SSMM					
Nombre proceso	Indisponibilidad de **infraestructura**	Bajo	Bajo	Bajo	Bajo	Bajo	Bajo
Nombre proceso	Indisponibilidad de **proveedores**	Bajo	Bajo	Bajo	Bajo	Bajo	Bajo
Nombre proceso	Indisponibilidad de **sistemas**	Bajo	Bajo	Bajo	Bajo	Bajo	Bajo
Nombre proceso	Ataque de **ciberseguridad**	Alto	Alto	Alto	Alto	Bajo	Bajo

Escala de impacto	
Impacto	Monetario
1. Bajo	Hasta un 0,01% del ingreso operacional de la institución. (Ref. MM$ 163)
2. Medio Bajo	Hasta un 0,03% del ingreso operacional de la institución. (Ref. MM$ 488)
3. Medio	Hasta un 0,06% del ingreso operacional de la institución. (Ref. MM$ 975)
4. Medio Alto	Hasta un 0,09% del ingreso operacional de la institución. (Ref. MM$ 1.453)
5. Alto	Más de un 0,09%

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

El impacto final incluye:
Mayor impacto hasta 24hrs. : automáticamente se trae el impacto más alto de la evaluación.
Tipo de impacto: Automáticamente se trae el impacto que resultó más crítico.
El **RTO** y el **MTPD** se completa según lo que dice RP

IMPACTO FINAL DEL PROCESO POR ESCENARIO					
Nombre del Proceso	ESCENARIO DE DISRUPCIÓN	MAYOR IMPACTO HASTA LAS 24 HORAS	Tipo de impacto	MTPD	RTO
	INDISPONIBILIDAD PARCIAL DE PERSONAL	Bajo	No aplica	No aplica	No aplica
	INDISPONIBILIDAD MASIVA DE PERSONAL (SSMM)	Crítico por Servicios Mínimos (SSMM)			
	INDISPONIBILIDAD DE INFRAESTRUCTURA	Medio	No aplica	No aplica	No aplica
	INDISPONIBILIDAD DE PROVEEDORES	Alto	Reputacional	1 hora	0,5
	INDISPONIBILIDAD DE SISTEMAS	Alto	Reputacional	1 hora	0,5
	ATAQUE DE CIBERSEGURIDAD	Alto	Reputacional	1 hora	0,5

RTO DEL PROCESO	RTO DEL PROCESO	0,5 horas
IMPACTO DEL PROCESO	IMPACTO DEL PROCESO	Alto

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

El impacto final incluye:

Mayor impacto hasta 24 hrs.: Automáticamente trae el impacto más alto de la evaluación

Tipo de impacto: Automáticamente trae el impacto que resultó más crítico

El RTO y MTPD: Se completa según lo que dice RP

IMPACTO FINAL DEL PROCESO POR ESCENARIO					
Nombre del Proceso	ESCENARIO DE DISRUPCIÓN	MAYOR IMPACTO HASTA LAS	Tipo de Impacto	MTPD	RTO
Nombre del Proceso	**INDISPONIBILIDAD PARCIAL DE PERSONAL**	**Bajo**	**No aplica**	**No aplica**	**No aplica**
Nombre del Proceso	**INDISPONIBILIDAD MASIVA DE PERSONAL (SSMM)**	**No Aplica**			
Nombre del Proceso	**INDISPONIBILIDAD DE INFRAESTRUCTURA**	**Bajo**	**No aplica**	**No aplica**	**No aplica**
Nombre del Proceso	**INDISPONIBILIDAD DE PROVEEDORES**	**Bajo**	**No aplica**	**No aplica**	**No aplica**
Nombre del Proceso	**INDISPONIBILIDAD DE SISTEMAS**	**Bajo**	**No aplica**	**No aplica**	**No aplica**
Nombre del Proceso	**ATAQUE DE CIBERSEGURIDAD**	**Bajo**	**No aplica**	**No aplica**	**No aplica**

RTO DEL PROCESO	RTO DEL PROCESO	No Aplica
IMPACTO DEL PROCESO	IMPACTO DEL PROCESO	Alto

Nombre del Proceso	ID Único Proceso	ESCENARIO DE DISRUPCIÓN	ENTRE 1 Y 2 HORAS	ENTRE 2 Y 6 HORAS	ENTRE 6 Y 24 HORAS	ENTRE 24 Y 36 HORAS	> 36 HORAS	MAYOR IMPACTO HASTA LAS 24 HORAS	Tipo de Impacto	MTPD	RTO
Realizar Atención y Soporte a Clientes (Reclamos, Consultas y Requerimientos)	36253	INDISPONIBILIDAD PARCIAL DE PERSONAL	Medio Bajo	Medio Bajo	Medio Bajo	Medio Bajo	Medio Bajo	Medio	No Aplica	No Aplica	No Aplica
Realizar Atención y Soporte a Clientes (Reclamos, Consultas y Requerimientos)	36253	INDISPONIBILIDAD MASIVA DE PERSONAL (SSMM)									
Realizar Atención y Soporte a Clientes (Reclamos, Consultas y Requerimientos)	36253	INDISPONIBILIDAD DE INFRAESTRUCTURA	Medio Bajo	Medio Bajo	Alto	Alto	Alto	Alto	Clientes	8 horas	3 horas
Realizar Atención y Soporte a Clientes (Reclamos, Consultas y Requerimientos)	36253	INDISPONIBILIDAD DE PROVEEDORES	Medio Bajo	Medio Bajo	Alto	Alto	Alto	Alto	Clientes	8 horas	3 horas
Realizar Atención y Soporte a Clientes (Reclamos, Consultas y Requerimientos)	36253	INDISPONIBILIDAD DE SISTEMAS	Medio Bajo	Medio Bajo	Alto	Alto	Alto	Alto	Clientes	8 horas	3 horas
Realizar Atención y Soporte a Clientes (Reclamos, Consultas y Requerimientos)	36253	ATAQUE DE CIBERSEGURIDAD	Alto	Alto	Alto	Alto	Alto	Alto	Clientes	8 horas	3 horas

MTPD (Periodo máximo tolerable de interrupción): Tiempo que podría llegar a ser inaceptable, en el cual habría impactos adversos como consecuencia de no proporcionar un

RTO (Tiempo de Recuperación Objetivo): Período de tiempo después de un incidente en el que: el producto o servicio se debe reanudar, o la actividad se debe reanudar o los recursos

RTO del Proceso: Corresponde al menor valor de los RTO de los escenarios críticos del

Impacto del Proceso: Corresponde al mayor impacto obtenido de los escenarios.

Nota: Para productos, servicios y actividades, el RTO debe ser menor que el MTPD.

RTO DEL PROCESO	3 horas
IMPACTO DEL	Alto

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Evaluación de Riesgos de Disrupción (RIA) Instrucciones de llenado:

La probabilidad y Evaluación de control, se evalúan con el RP de acuerdo a escalas definidas

El riesgo Inherente y Riesgo residual se calculas automáticamente, considerando impacto, probabilidad y ev. de control

RESULTADOS BIA

Etapas o Actividades	Factor de Riesgo (De evalúan todos los escenarios de indisponibilidad)	Factor de Riesgo Específico	Controles Identificados	Tipo de Impacto	MAYOR IMPACTO HASTA LAS 24 HORAS	Probabilidad	Ev. De control	Riesgo Inherente	Riesgo Residual Final
En qué participa el factor de riesgo	Indisponibilidad parcial del personal clave	Indisponibilidad del **personal clave**	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	Medio alto	3 Ocasional	[illegible]	Medio alto	Medio alto
En qué participa el factor de riesgo	Indisponibilidad masiva del personal	Indisponibilidad de **Ausencia masiva**	Críticos por Servicios Mínimos (SSMM)						
En qué participa el factor de riesgo	Infraestructura: Corte de energía eléctrica, interrupción de servicios básicos	Imposibilidad de acceso o uso de las oficinas	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	2 Medio Bajo	[illegible]	2 Suficiente	Bajo	Bajo
En qué participa el factor de riesgo	Infraestructura: Indisponibilidad de un edificio o conjunto de edificios	Imposibilidad de acceso o uso de las oficinas	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	2 Medio Bajo	[illegible]	2 Suficiente	Bajo	Bajo
En qué participa el factor de riesgo	Indisponibilidad por proveedores	Indisponibilidad del servicio **prestado por el proveedor** (Ir por proveedor específico)	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	2 Medio Bajo	[illegible]	2 Suficiente	Bajo	Bajo
En qué participa el factor de riesgo	Indisponibilidad de sistemas	Indisponibilidad de **aplicación** (este análisis se hace por cada aplicación)	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	2 Medio Bajo	[illegible]	2 Suficiente	Bajo	Bajo
En qué participa el factor de riesgo	Indisponibilidad de sistemas	Indisponibilidad **total de las aplicaciones**	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	2 Medio Bajo	[illegible]	2 Suficiente	Bajo	Bajo
En qué participa el factor de riesgo	Escenario Ciberataque	Escenario Ciberataque: Ransomware Windows	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	2 Medio Bajo	[illegible]	2 Suficiente	Bajo	Bajo
En qué participa el factor de riesgo	Escenario Ciberataque	Escenario Ciberataque: Denegación de Servicio y Malware	Nombre BCP: Última prueba realizada al sistema/proveedor/personal:	Clientes	2 Medio Bajo	[illegible]	2 Suficiente	Bajo	Bajo

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

N°	Etapas o Actividades	Factor de Riesgo	Factor de Riesgo Específico	Controles identificados	BIA Tipo de Impacto	BIA MAYOR IMPACTO HASTA LAS 24 HORAS	Probabilidad	Evaluación del Control	Riesgo Inherente	Riesgo Residual	Respuesta al Riesgo de Continuidad
1	En que participa el factor de riesgo.	Escenario Personal: Indisponibilidad personal clave	Indisponibilidad del personal clave del proceso **Lista de personal crítico**	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	Clientes	4 Medio Alto	2 Poco Probable	1 Deficiente	Medio	Medio	No se requiere actualizar o construir un plan de continuidad, se debe mantener el plan de pruebas.
2	Servicios Mínimos	Escenario Personal: Indisponibilidad masiva de personal	Escenario Personal: Indisponibilidad masiva de personal (Huelga, Servicios Mínimos definidos por la Dirección del Trabajo)	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	$N/A						
3	En que participa el factor de riesgo.	Escenario Infraestructura: Indisponibilidad de un edificio o conjunto de edificios	Imposibilidad de uso de las oficinas por: imposibilidad de acceso, corte de energía eléctrica o interrupción de servicios básicos: **dirección (áreas centrales)**	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	Clientes	1 Bajo	1 Muy Poco Probable	1 Deficiente	Bajo	Bajo	No se requiere actualizar o construir un plan de continuidad, se debe mantener el plan de pruebas.
4	En que participa el factor de riesgo.	Escenario Proveedores: Indisponibilidad de servicios prestados por proveedores	Indisponibilidad del servicio prestado por el proveedor: **Nombre proveedor y número de contrato**	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	Clientes	1 Bajo	1 Muy Poco Probable	1 Deficiente	Bajo	Bajo	No se requiere actualizar o construir un plan de continuidad, se debe mantener el plan de pruebas.
5	En que participa el factor de riesgo.	Escenario Sistemas/Aplicaciones: Indisponibilidad de una aplicación / servicio TI crítico para la ejecución del proceso	Indisponibilidad de la aplicación: **Nombre aplicación.**	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	Clientes	1 Bajo	1 Muy Poco Probable	1 Deficiente	Bajo	Bajo	No se requiere actualizar o construir un plan de continuidad, se debe mantener el plan de pruebas.
6	En que participa el factor de riesgo.	Escenario Sistemas/Aplicaciones: Indisponibilidad masiva de aplicaciones/ servicios TI /	Indisponibilidad total de las aplicaciones	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	Clientes	1 Bajo	1 Muy Poco Probable	1 Deficiente	Bajo	Bajo	No se requiere actualizar o construir un plan de continuidad, se debe mantener el plan de pruebas.
7	En que participa el factor de riesgo.	Escenario Sistemas/Aplicaciones: Indisponibilidad masiva de aplicaciones/ servicios TI / comunicaciones	Escenario Ciberataque Ransomware Windows: **Enumerar sistemas/aplicativos Windows (considerar también servidores)**	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	Clientes	1 Bajo	1 Muy Poco Probable	1 Deficiente	Bajo	Bajo	No se requiere actualizar o construir un plan de continuidad, se debe mantener el plan de pruebas.
8	En que participa el factor de riesgo.	Escenario Sistemas/Aplicaciones: Indisponibilidad masiva de aplicaciones/ servicios TI / comunicaciones	Escenario Ciberataque Malware	**Nombre BCP, Última prueba realizada al sistema/proveedor/personal: Resultado prueba factor de riesgo en específico:**	Clientes	1 Bajo	1 Muy Poco Probable	1 Deficiente	Bajo	Bajo	No se requiere actualizar o construir un plan de continuidad, se debe mantener el plan de pruebas.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Matriz de Impacto v/s probabilidad.

Matriz de Impacto vs Probabilidad						
Probabilidad	Muy frecuente	Medio Bajo	Medio Alto	Alto	Alto	Alto
	Frecuente	Medio Bajo	Medio	Medio Alto	Alto	Alto
	Ocasional	Bajo	Medio Bajo	Medio	Medio Alto	Alto
	Poco Probable	Bajo	Medio Bajo	Medio Bajo	Medio	Medio Alto
	Muy Poco Probable	Bajo	Bajo	Bajo	Medio Bajo	Medio Bajo
		Bajo	Medio Bajo	Medio	Medio Alto	Alto
		Impacto				

Como se puede ver en la **Matriz de Impacto vs Probabilidad**, el **Nivel de Riesgo** se representa a través de una escala cualitativa, desde un nivel de exposición **Bajo**, hasta un nivel de exposición **Alto**.

4.2.2.2. Planes de Contingencia

- Dependiendo de la respuesta al riesgo presentado, se deben de generar actualización o creación de BCP (Planes de Contingencia) asociados a los procesos, lo anterior solo para procesos definidos como críticos. Estos BCP permiten responder a la materialización de los escenarios de contingencia definidos, los cuales son actualizados al menos una vez al año.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- La herramienta debe contener un catálogo de BCP cargados en el Sistema. Este catálogo debe contener datos como nombre del archivo, código del BCP, usuario que realiza la carga, fecha de carga, escenario de disrupción.
- Al crearse un nuevo BCP, la herramienta debe ser capaz de entregar un Código correlativo (no repetido) con el cual será identificado posteriormente el nuevo BCP, de acuerdo a la siguiente clasificación:

  - ✓ BCP02xx – Escenario sin Infraestructura
  - ✓ BCP03xx – Escenario sin Sistema
  - ✓ BCP05xx – Escenario de Ciberataque
  - ✓ BCP07xx – Escenario de Ausencia masiva de personal
  - ✓ BCP08xx – Escenario sin proveedor
  - ✓ BCP09xx – Escenario de Ausencia parcial de Personal

- De igual manera se puede obtener como respuesta al riesgo presentado en el BIA, la necesidad de realizar una prueba al BCP definido.
- La herramienta debe permitir la carga de Informe Ejecutivo de Prueba y Formulario de Evaluación de Pruebas (Informe Ejecutivo y Formulario de Pruebas).

Informe Ejecutivo y Excel de prueba.

Instrucciones de llenado

El formulario corresponde a un archivo Excel, el cual contiene 3 etapas. En la siguiente tabla se muestra el nombre de cada etapa, con una descripción de su contenido:

Contenido Formulario	
Etapa Formulario	Descripción
Planificación	Esta etapa se indica lo siguiente:

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

	Las características del plan evaluado, donde se indica el código y nombre del plan a probar, el tipo de prueba (escritorio, simulación o real) y el área de la prueba, ya sea áreas centrales, sucursales o filiales. Detalle del Escenario, donde se indica el escenario de la prueba, el alcance, las exclusiones, por qué se está realizando la prueba y su impacto. La coordinación, donde se indica los datos de los coordinadores, veedores y si existe alguna coordinación con comunicaciones. Los participantes de la prueba, donde se detallan los participantes coordinadores y ejecutantes de la prueba. En el anexo n°1 se incorporan todos los participantes de la prueba ya sea personal Banco o externos.
Desarrollo	En esta etapa se indica la fecha y hora de inicio y término de la prueba. Además, se describen todas las actividades realizadas y la vuelta a la normalidad (acción, responsable y duración).
Evaluación	En esta etapa se muestra el resultado de la prueba según las métricas de evaluación, los participantes y recursos. Por otro lado, se realiza un análisis donde se describe lo observado, se adjuntan los archivos, correos, documentos, entre otros, que permitan evidenciar la correcta ejecución del proceso y se detalla el plan de acción en caso de que sea necesario aplicar alguno.

Informe Ejecutivo de prueba

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Informe Ejecutivo Prueba Proceso " "
Gerencia de Riesgo Operacional y Tecnológico

Proceso Asociado	
Escenario de Prueba	
Fecha de creación de informe	

Contexto:

- Fecha de prueba:
- Escenario a probar:
- Tipo de prueba:
- Personal participante:
- Estrategia contingencia:

Objetivo:

Resumen ejecutivo:

Consideraciones:

Resultado:

Planes de Acción:

1. Detalle:
   Responsable
   Fecha:

Formulario de Evaluación de Pruebas Continuidad

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Informe Pruebas de BCPXXXX					
Planificación					
	Características Plan Evaluado				
	Código del Plan		**Fecha última actualización del Plan**		
	Nombre del Plan		**Fecha a realizar Prueba**		
	Tipo de Prueba		**Área de Prueba**	**Nombre Sucursal**	
	Detalle del Escenario				
Detalle	**Sin Personal**	**Sin Infraestructura**	**Sin Proveedor**	**Sin Sistemas**	**Condición de la Prueba**
	Alcance de la Prueba				
	Exclusiones de la Prueba				
	Justificación				
	Impacto		**Detalle**		
	Coordinación				
Coordinación	**Coordinadores**	**Cargo / Nombre**	**Área**	**Teléfono**	**Correo**
	Responsable del Plan				
	Coordinador del Plan				
	Veedor				
	Coordinación con Comunicaciones		**Lugar de comunicado**	**cha/Hora de Comunica**	
	Participantes de la Prueba *(Informar solo los principales coordinadores y ejecutantes, en anexo n°1 ingresar lista completa)*				
Participar	**Nombre**	**Cargo**	**Área**	**Teléfono**	**Correo**

Desarrollo	**Datos de la Prueba**				
	Inicio			**Término**	
	Fecha	**Hora**		**Fecha**	**Hora**
	Actividades a Realizar				
N°	**Acción realizada**	**Responsable**		**Duración**	
	Contingencia	**Nombre**	**Cargo**	**T en minutos**	
1					
2					
3					
N°	**Vuelta a la Normalidad**	**Nombre**	**Cargo**	**T en minutos**	
1					

Resultado				
Métricas				**Resultado de la Prueba**
Indicador		**Valor de aceptación**	**Valor realizado**	
1				% Satisfacción de la Prueba
Ponderación Cálculo de Efectividad				*0.0%*
Indicador		**Ponderación**	**Porcentaje Logrado**	**Resultado**
1	*Escalamiento y activación*	*20%*		*Insatisfactorio*
2	*Actividades de Coordinación y Comunicación*	*20%*		
3	*Procedimiento Contingencia*	*60%*		

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Evaluación		Detalles de la prueba	Respuesta	Planificado	Real	% de participación
	1	Participa el personal titular				
	2	Participa el personal de reemplazo				
	3	Participo proveedor		Nombre del proveedor		
	4	Se conto con los recursos para la prueba		Observación		

Análisis
Observaciones a la Prueba: *Conclusiones:*

Evidencia (en "tipo" informar a que evidencia corresponde, ej: correo de coordinación, fotos de participantes, otros)					
Aviso Incidente a Jefe Depto. Recaudaciones	*Aviso Incidente a Subgerente de Operaciones de*	*Aviso Incidente a GNT*		*Declaración de Contingencia*	*Nómina enviada por Empresa en Convenio*

Plan de Acción					
Detalle					
Responsable del Plan Acción		Cargo		Área	
Responsable de Seguimiento		Cargo		Área	
Fecha de compromiso		Entregable comprometido			

Responsable del Informe					
Nombre		Cargo		Área	

4.2.2.3. Gestión de Continuidad de Negocio

- La herramienta debe tener un panel de control, que incluya información concentrada de todos los procesos. Este panel se alimenta de datos que se extraen desde la Ficha del proceso, BIA, RIA y BCP. Debe contener datos como:

  - ✓ Nombre del proceso.
  - ✓ Responsable de proceso.
  - ✓ Escenarios analizados.
  - ✓ Fechas y resultados obtenidos de las actualizaciones de los BIA- RIA.
  - ✓ BCP asociados los distintos escenarios.
  - ✓ Fecha de actualización de los BCP.
  - ✓ Nombre y código de los BCP.
  - ✓ Sistemas, proveedores, etc. identificado en los BCP, su criticidad y contingencias.
  - ✓ Fechas de la última prueba realizada con su resultado y planes de acción asociados.
  - ✓ Analista asignado.
  - ✓ Otros.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Adicionalmente, la herramienta debe contar con un panel de seguimiento de la planificación anual del área de continuidad, donde se encuentren todas sus actividades, tareas, BIA- RIA, BCP, planes de acción y otros. el panel debe poder:

  - ✓ Permitir la carga de planificación anual y otras actividades relacionadas a la gestión propia del área.
  - ✓ Identificar planificación por analistas.
  - ✓ Indicar estados de avance, mediante hitos previamente definidos para cada una de las actividades.
  - ✓ Identificar actividades que se encuentren dentro del plazo, próximas a vencer (levantando alertas a Jefatura) o atrasadas.
  - ✓ Entregar un porcentaje de avance general de la planificación anual del área.

- Adicionalmente, debe ser posible cargar Planes de recuperación de desastre (DRP), el cual contiene procedimientos para restaurar y volver a las actividades normales del negocio una vez superada la contingencia.
- Deseable que la herramienta posea un módulo de prueba (BCP/DRP).

4.2.3. Base de Pérdida

Deseable la herramienta debe tener la facultad de gestionar la pérdida de Banco, que permita cargar RO base de pérdidas

4.2.3.1. Gestión de pérdidas y Apetito de riesgo

La Gerencia de Riesgos no Financieros ha generado un modelo para contar con una fuente confiable de eventos de pérdida por riesgo operacional, para lo cual, ha definido la existencia de una base de datos de pérdidas, que se alimenta de datos formales y confiables de la Corporación, a partir de un proceso de recolección, no solo con el objetivo de registrar las pérdidas sino que también entender sus causas raíces y poder realizar seguimientos adecuados respecto si las pérdidas están acorde con lo aceptado por la alta administración.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Apetito de Riesgo

Se ha definido un apetito de riesgo operacional, basado en un ratio que combina las pérdidas operacionales y la actividad económica de la entidad. Para la cuantificación de las pérdidas se utiliza el Total de Pérdidas Operacionales, que emana desde Contabilidad. Para medir la actividad económica se utiliza el Total de Ingresos Operacionales, dato que emana desde los informes de Contabilidad.

Para poder gestionar las pérdidas operacionales debemos contar con distintos elementos tales Como:

- Contar con una base de pérdidas por riesgo operacional (BBPP) estructurada
- Definir las fuentes de alimentación
- Asignación de los eventos de pérdidas a las distintas cuentas contables de pérdidas operacionales
- Asignación de las pérdidas operacionales a los procesos formales de la corporación
- Asignación de las pérdidas a las distintas causas y líneas de negocio definidas por Basilea
- Generación de reportes de pérdidas
- Monitorear la evolución de las pérdidas Análisis de pérdidas más relevantes

4.2.4. Servicio y puesta en marcha con proveedor directo

El servicio y puesta en marcha de la solución debe ser realizada por el proveedor directo.

4.2.5. Contraloría (Auditoría Interna)

4.2.5.1. Planificación para un Periodo

- Mapa de materias/procesos/entidades: La herramienta debe permitir la carga/integración con el Mapa de Procesos del Banco, agregar otras materias o entidades auditables.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Permitir cargar los resultados de las evaluaciones de riesgo del módulo que gestiona la Gerencia de Riesgos no Financieros
- Incorporar un ranking materias a ser auditadas, en base a diversos criterios/factores de riesgo inherentes/residuales y objetivos estratégicos, que tienen distintas ponderaciones y de cálculo final por procesos/materias/entes auditables.
- En punto anterior, debe ser posible integrar también entre otros, los resultados de la ejecución de indicadores continuos, resultados de ejecución de pruebas presenciales y seguimiento de los planes de acción.
- La herramienta en base a los niveles de riesgo, dada ciertas definiciones de prioridad, debe proponer auditorías a desarrollar.
- Tender hacia un Mapa de Riesgo de Auditoría lo más dinámico posible.
- Generar en lo posible, un Mapa de Aseguramiento sobre los procesos/entes auditables y tipos de riesgos, considerando la identificación de otros proveedores de aseguramiento interno y externo, para evitar duplicaciones de esfuerzos y vacíos de aseguramiento sobre lo relevante.
- Debe administrar los recursos de auditoría (Personas, Presupuesto), sus perfiles y asignaciones.
- Permitir una programación detallada de los trabajos que desarrollará Auditoría Interna (objetivos, tipos de riesgos relevantes, plazos, etc.) y posterior control del avance de los trabajos.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

En el análisis de controles, poder relacionar bidireccionalmente a pruebas y resultados que se efectúen en otras entidades que no sean procesos, por ejemplo, de la auditoría del proceso a las auditorías de cumplimiento de controles en Sucursales,

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Plataformas, etc. y que genere retroalimentación, en lo posible automática, a la efectividad de los controles del proceso.

Lo mismo en cuanto a poder relacionar información de auditoría continua, en lo posible con un cálculo automático, que se pueda importar de otras aplicaciones, como por ejemplo, resultados en SQL o Power BI.

Las observaciones de auditoría, el sistema pueda proponer su calificación en base a los siguientes criterios:

ALTAS	✓ Asociadas a **Riesgos Inherentes Altos/Medios Altos** con **Efectividad de Controles Regulares o Deficientes.**
MEDIAS	✓ Asociadas a **Riesgos Inherentes Altos/Medios Altos** con **Efectividad de Controles Suficientes.** ✓ Asociadas a Riesgos **Inherentes Medios** con Efectividad de Controles **Regulares o Deficientes.**

Generación de Reportes BI, de acuerdo a los resultados de las auditorias, y que la herramienta proponga una calificación de la auditoría, en función de los riesgos relevantes y controles analizados en la auditoría.

EFECTIVO	✓ Sólo deben contener niveles de **Efectividad de Controles de Buenos a Óptimos.**
SATISFACTORIO	✓ Sólo deben contener niveles de **Efectividad de Controles Suficientes, Buenos y/o Óptimos**, con un máximo de 3 controles Suficientes.
REGULAR	✓ Existen Riesgos **Inherentes Medio Altos** con Efectividad de Controles **Regulares o Deficientes.**
DEFICIENTE	✓ Existen Riesgos **Inherentes Altos** con Efectividad de Controles **Regulares o Deficientes.**

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

También la herramienta puede trabajar bajo los mismos conceptos de calificación, con otros factores de cálculo, por ejemplo para una entidad Sucursales, donde el foco es más de eficacia operativa o cumplimiento de controles.

4.2.5.2. Seguimiento de Observaciones

Ingreso de planes de acción por las áreas auditadas, así como posterior ingreso de respuestas y evidencia de cumplimiento de planes (licencias light).

Debe permitir un esquema de atribuciones que escale vía mail u otros medios a usuarios fuera o dentro de la aplicación, para:

- Aceptación de Plazos de Planes de Acción
- Prórrogas
- Escalamiento de discrepancias

Es la etapa post auditoría, en la cual se valida el cumplimiento de los planes de acción que las áreas auditadas comprometieron en las Observaciones y que ingresaron a través de portal o de otra manera. Para esta tarea se requiere una funcionalidad para que las áreas puedan ingresar sus respuestas a las observaciones, tener alertas y solicitudes de prórrogas (tipo Portal). El cumplimiento de las observaciones, en el seguimiento, debe poder actualizar o proponer el nivel de riesgo del mapa de materias. En la medida de lo posible, asociar a las observaciones en la herramienta, algún indicador KRI o KCI que permita analizar el cumplimiento desde fuentes independientes al responsable del plan de acción.

Fuentes del seguimiento:

- Contraloría
- Comisión para el Mercado Financiero (CMF)
- Auditores Externos
- Autoevaluación de Gestión
- Otros Organismos fiscalizadores, si procediera.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Etapas del seguimiento:

- Recepción y Aceptación de Planes de Acción
- Generación de Alertas y Obtención de Respuestas
- Validación de Ejecución de los Compromisos
- Resultado Seguimiento

4.2.5.3. Información de Gestión y Control de Calidad.

La herramienta debe generar paneles de fácil uso e interpretación para temas como:

- Cumplimiento Plan de Auditoría
- Cumplimiento de Etapas en la Ejecución de los Trabajos
- Estado del Seguimiento de Compromisos
- Que permite extraer información para crear Indicadores continuos asociados al mapa de materias.
- Generar paneles de errores de ingreso (ayudas y alertas)
- Generar alertas de Vencimientos de Planes de Acción, automatizando correo de aviso de planes de acción a una fecha dinámica que se pueda definir como, por ejemplo, los vencidos a fin de mes.
- Automatizar el proceso mensual de asignación de seguimiento a los auditores
- Contar con un semáforo que permita ver el estado de los seguimientos Envío de reporte de auditorías en curso o próximas a partir en el mes.
- Generación automática de formularios
- Historial: Debe manejar versiones del mapa de materias por periodos y la evolución de éste. Además, se debe mantener historia de los trabajos de auditoria de los periodos anteriores. Esto en conjunto con la migración que se deberá realizar de los datos del actual sistema.
- Debe permitir adjuntar documentos de cualquier extensión e incluso imágenes y URL

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

4.2.6. Reportes

- La herramienta debe permitir generar mapas de calor por tipo de riesgo inherente y/o riesgo residual.
- Debe generar reporte consolidado de la información
- La herramienta debe contar con la opción de exportar información para organismos reguladores y auditores. En formatos como excel, word o pdf.
- Administración de hallazgos y requerimientos (Isues Management).
- La herramienta permita interactuar con otras herramientas de inteligencia de negocio como por ejemplo PowerBI.
- Reportes configurables y perfilados, según rol consultante.
- Reportes exportables y descargables en formato PDF y Excel.

4.2.7. Demo

El proveedor debe disponer al Banco una Demo que permita observar, de manera práctica, los servicios ofertados por los oferentes para dar una bajada de los servicios requeridos, permitiendo observar la complejidad de las configuraciones, visualizaciones de las pantallas, registro y gestión de la información de los trabajadores hasta la respectiva reportería y tableros que correspondan al servicio en revisión, para lo cual, se elaboró una guía mínima de lo que será sujeto a evaluación por parte de BancoEstado.

La demo debe tener una duración 3 horas máximo, mostrando todos requerimientos funcionales solicitados en las bases técnicas.

4.3. Plazo del servicio

El servicio tendrá una duración de 36 meses a contar de la fecha de adjudicación del contrato.

Al término del contrato o en caso que el Banco estime que no se cumplen con los servicios establecidos u otro incumplimiento, la empresa deberá proveer todas las facilidades para realizar la transición del servicio a un nuevo proveedor o lo que el Banco estime realizar, asegurando la continuidad operacional, así como la entrega de los datos e información en un formato legible o establecido por el Banco sin costo adicional para el Banco.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

4.4. Horario del servicio

El horario del servicio es 7x24.

4.5. Estrategia de Implementación y puesta en marcha del servicio

Una vez adjudicado el servicio, BancoEstado realizará el proceso de recepción formal, para todos los puntos exigidos en las bases. Será requisito la aprobación total de la recepción por parte de BancoEstado.

El proveedor deberá explicar claramente cómo se va a poner en funcionamiento el servicio. De lo anterior, debe incluir en su oferta una Estrategia y un Plan de Implementación. Se considera un período de implementación del servicio por parte del proveedor, destinado a preparar su total operación, y debe indicar el plazo de dicha implementación. Este período de implementación será de costo del Proveedor y debe considerar al menos los siguientes ítems:

- Recepción formal del servicio por parte del Banco.
- Descripción del Plan implementación y puesta en marcha, carta Gantt con las fases o etapas del proceso. Fase de implementación, Plan Transición y migración de los servicios.
- Capacidad de implementarse modularmente e integrarse con sistemas Banco de acuerdo al servicio requerido.
- Estrategia de Entrenamiento y Capacitación de herramienta, de manera presencial o telemática, manuales operativos, procedimientos, entre otros.
- La capacitación debe ser en español así como todos los materiales entregados a BancoEstado, tales como manuales de uso, tutoriales, parametría, presentaciones, personalización, configuración de los módulos, títulos de los módulos, pasantías, soporte, como también todas las instancias de comunicación con el Banco, considerando distintos canales.
- Proveer un servicio de acompañamiento en las primeras etapas del servicio.
- Incluir enlaces de comunicaciones entre el Banco, Proveedor y terceros que formen parte de la solución.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Proponer equipo de gobierno.
- Establecer los procesos de la planificación y certificación. Esto incluye la preparación de los sistemas que apoyarán estos procesos.
- Pruebas para Inicio del Servicio.
- Configuración de los sistemas y servicios de soporte.

5. Requerimientos Técnicos

5.1. Arquitectura Aplicativa

A continuación, se establecen los requerimientos técnicos vinculados al ámbito de Arquitectura Aplicativa en relación a licitación de una solución Gestión de Gobernanza, Riesgo y Cumplimiento para los equipos de la Gerencia de Riesgos no Financieros y Contraloría de BancoEstado.

La solución de software a licitar requiere de una propuesta de solución de software integral que cumpla con los requerimientos técnicos que se especifican a continuación.

El objetivo principal de esta licitación es adquirir un servicio del tipo SaaS (Software as a Service) en el que el oferente es el responsable de disponibilizar y mantener un servicio de software que garantice la disponibilidad y la seguridad del software y de sus datos.

5.1.1. Requerimientos Generales

A continuación, se presentan los requerimientos generales, que desde el punto de vista de arquitectura aplicativa se exigirán a las soluciones oferentes.

5.1.1.1. Mecanismo de integración Batch

Se espera que la solución propuesta provea el modelo de operación bajo modalidad batch que considere la carga y descarga masiva de información. El proveedor debe garantizar que el tiempo de respuesta del procesamiento batch se adecue al tiempo de procesamiento definido por el Banco y mantener conexión hacia el Banco mediante enlace dedicado.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.1.1.2. Navegadores estándar Banco

La Interfaz web de la solución deberá ser responsiva y estar soportada para los siguientes navegadores y versiones que son el estándar Banco para las estaciones de trabajo Windows 10 o superior:

- Internet Explorer 11
- Explorer Edge 86
- Google Chrome 85

Además, la Interfaz web de la solución deberá ser responsiva y estar soportada para el siguiente navegador y versión es parte del estándar Banco para las estaciones de trabajo Windows 8.1:

- Google Chrome 78

En el caso de acceso a la solución desde fuera de las instalaciones del Banco, el proveedor debe explicitar los navegadores y versiones mínimas soportadas.

5.1.1.3. Responsividad de la solución

La Interfaz web de la solución deberá ser responsiva, para poder ser visualizada en Tablet o cualquier dispositivo móvil.

Se espera que el proveedor debe indicar si la solución para dispositivos móviles es:

- App Nativa
- App Hibrida (carcasa más aplicación web)
- Sólo Web

5.1.1.4. Autenticación

La solución debe contemplar un mecanismo de integración con el AD Azure del Banco que permita la autenticación en línea mediante las credenciales Banco de los usuarios; idealmente SAML.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.1.1.5. Autorización

La solución debe contemplar la implementación de roles y perfiles que se puedan mantener y ajustar según el Banco defina.

5.1.1.6. Administración de la autorización de la solución

La administración de la autorización de la solución debe ser realizada por el Banco.

5.1.1.7. Tiempos de respuesta portal web

La solución deberá asegurar tiempos de respuesta para una consulta unitaria inferiores a 3000 ms

5.1.1.8. Información digitalizada en la solución

El almacenamiento de la información digitalizada en la solución deberá ser mantenida el tiempo que el Banco defina, así como garantizar su acceso (tiempo y formato) según las definiciones del Banco.

5.1.1.9. Ambiente DevOps

La solución soporta ambientes Desarrollo, Test, QA, Producción. Soporta DevOps. Todo eso con el fin de que el Banco pueda probar los procesos de integración (batch y en línea), además de actualizaciones a la solución del proveedor de forma previa al despliegue en Producción.

5.1.1.10. Envío de correos con dominio BancoEstado

Para efectos de envío de correos como parte de la funcionalidad de la solución, el proveedor deberá integrarse a la solución que el Banco defina, sea mediante API REST o similar, y a una solución on-premise u otro mecanismo en el caso Nube.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.2. Arquitectura Técnica

El oferente debe ser responsable de disponibilizar y mantener la infraestructura y el software que requiere la solución. Además, debe garantizar la disponibilidad y la seguridad tanto del aplicativo como la información (datos) que utiliza.

El objetivo es adquirir una Solución del tipo SaaS, en la Nube, Es decir, se requiere una propuesta de solución de software integral que se consigue a partir de servicios en la nube. Este debe considerar un modelo de facturación por uso.

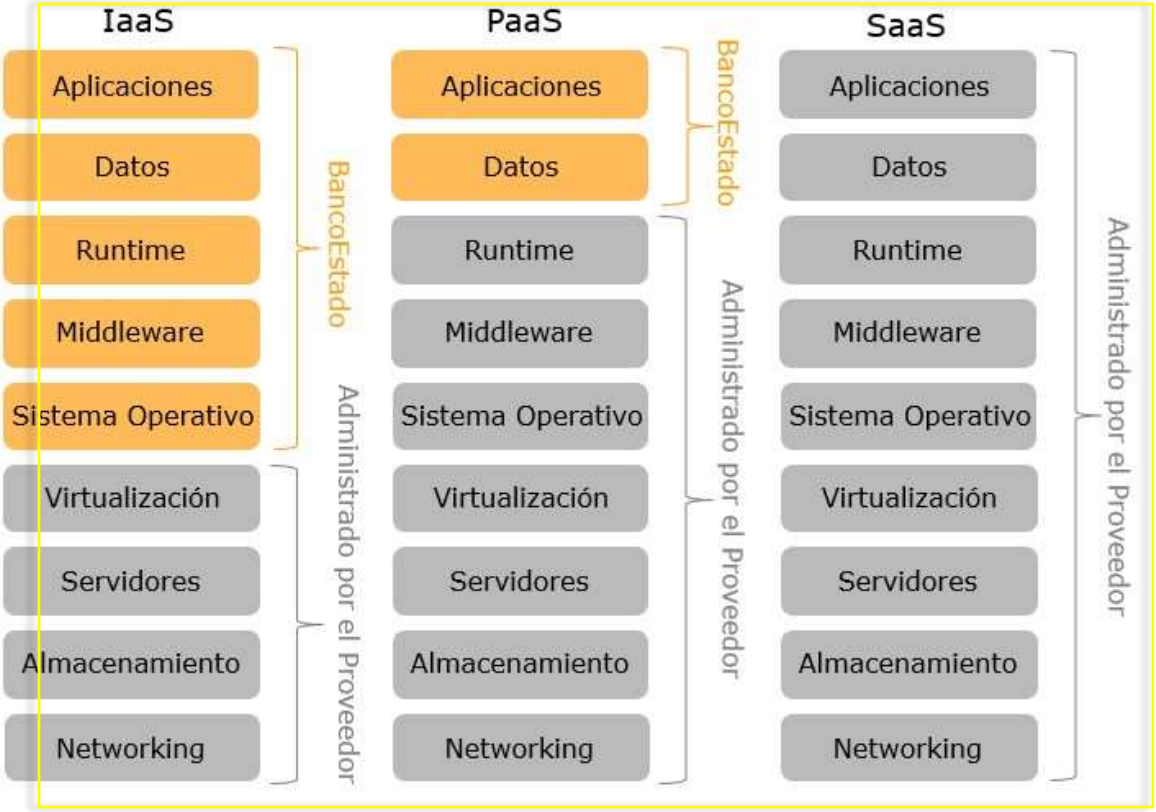
5.2.1. Requerimientos Tecnológicos

5.2.1.1. Entorno de computación en la nube

El objetivo general de adoptar los servicios de computación en la nube es adoptar un enfoque orientado a los servicios para proporcionar un entorno de TI empresarial ágil donde la infraestructura y los servicios comunes se puedan compartir, reutilizar y aprovisionar a pedido para satisfacer las necesidades comerciales, mientras se logran ahorros en los costos.

.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile



El marco de computación en la nube, según diagrama anterior, proporciona una descripción general de alto nivel de los componentes funcionales clave para los Servicios de computación en la nube que requiere la Solución Tecnológica, para este caso una solución Nube en modalidad SaaS.

5.2.1.2. Requerimientos de Experiencia del oferente

Mencionar la experiencia en la provisión de servicios SaaS a organizaciones de tamaño similar al Banco; Indicar al menos dos casos de éxito, detallando la solución SaaS y el periodo de tiempo que ya se encuentra en producción.

5.2.1.3. Requerimientos técnicos para una Solución SaaS

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

2.1. Indicar las ubicaciones geográficas donde estará disponible la solución y datos. Indicar Latencia ofrecida: Describir el tiempo total que tarda un paquete de datos (información) en viajar de un nodo origen a otro nodo destino. (De un centro de datos a otro).

5.2.1.4. Recuperación ante desastres y continuidad del Servicio

El oferente debe describir y adjuntar los diagramas de los mecanismos de Recuperación ante desastres. Esta información permitirá identificar las acciones de respuesta ante posibles eventos que puedan afectar la continuidad del servicio para BancoEstado (interrupciones leves o moderadas que afecten el Uptime).

Se requiere que la propuesta de servicio considere la capacidad de Resiliencia, la cual se entiende como la capacidad de estar siempre preparado para lo impredecible. Es la habilidad de una organización de absorber el impacto de una interrupción del negocio a la vez que continúa proporcionando el nivel de servicio requerido. *Debiese contar un respaldo*

Además, estos respaldos de datos como aplicativo deben estar en chile por un tema de continuidad operativa.

RTO (Tiempo de Recuperación) del Servicio: 36 horas

RPO (Tipo de Recuperación) del Servicio: 1 semana (semana de respaldo)

5.2.1.5. Servicio de Migración e implementación de la Solución

Solo para el caso que la solución amerite migración de datos desde el Banco, el oferente debe proporcionar un plan, que considere acompañamiento y soporte al proceso de migración. Se requiere que el oferente presente un plan de implementación, además de un plan capacitación a los usuarios del Banco, según sea necesario. El plan debe incluir todas las actividades requeridas tanto para la implantación de la solución como las migraciones que se requirieren para operar sin dificultad con la nueva solución. Cronograma estimado y los recursos necesarios para dichas actividades.

Nivel de Cumplimiento del Plan de Migración: 20% desviación. (Retraso)

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Nivel de Cumplimiento del Plan de Capacitación: 10% desviación. (Retraso)

Nivel de Cumplimiento del Plan de Implementación: 10% desviación. (Retraso)

5.2.1.6. Modelo de Operación del Servicio

5.2.1.6.1. Servicio de Monitoreo

Se entiende como los diversos sistemas de alertas y dashboards que el oferente deberá gestionar de manera constante durante las 24 horas del día, y les permite controlar el correcto funcionamiento del servicio, anticipando la detección de eventos que pueden afectar su disponibilidad (Uptime del servicio) y la continuidad operativa de BancoEstado, esto se denomina Monitoreo Proactivo. Además, los entregables del servicio de monitoreo, permitirá que BancoEstado evalúe de forma constaté la calidad del servicio acordado de acuerdos a los “Acuerdos de Nivel de Servicio” (SLA) establecidos por ambas partes.

Por esta razón, las empresas oferentes deben informar sobre su “**modelo de monitoreo**” al servicio ofertado, y al menos debe contar con lo siguiente: (Justificar cómo resuelve el servicio cada ítem).

- ✓ Contar con las herramientas de monitoreo (que permita realiza un análisis predictivo) y sus procesos de recolección de datos.
- ✓ Contar con un sistema de notificaciones y alertas respecto a la continuidad operativa, fraude, incidentes de seguridad, otros.
- ✓ Contar con los canales de comunicación ante la detección de un evento o incidente.
- ✓ Contar con las vistas y paneles de monitoreo que será otorgado a BancoEstado y permitirá controlar la estabilidad, operatividad y seguridad del servicio.
- ✓ Descripción de su gobierno y gestión: metodología de trabajo, certificaciones de operación, gestión de indicadores, servicios gestionados, otros.
- ✓ Descripción de reportes de monitoreo que serán entregados periódicamente a BancoEstado.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ O que el Banco pueda crear sus propios paneles de gestión o monitoreo con alguna herramienta Banco interactúe con esta solución.
- ✓ Modalidad de Monitoreo proactivo: 7x24x365
- ✓ Modalidad de Monitoreo reactivo: A demanda.

5.2.1.6.2. Servicio de Atención de Soporte Tecnológico

Este servicio comprende la atención de los siguientes ítems en el ámbito técnico:

- Requerimientos
- Soporte
- Resolución de problemas/incidentes.

Para dar el servicio el modelo de Operación deberá contar con los siguientes:

- Contar con canales de atención específicos según el ámbito de la atención, es decir, para Requerimientos, Soporte y para Resolución de problemas/incidentes.
  - ✓ Disponibilidad del canal correo contacto: 99,95%
  - ✓ Disponibilidad del canal telefónico: 7x9 (Requerimientos y Soporte)
  - ✓ Disponibilidad del canal telefónico: 7x24x365 (Resolución de Problemas/Incidentes)
- Un ejecutivo de cuentas receptivo (o un equipo de personal dirigido por un ejecutivo de cuentas) asignado a BancoEstado para satisfacer sus necesidades al proporcionarles un soporte administrativo diario y continuo.
  - ✓ Modalidad de Atención: 5x9.
- El equipo del Proveedor debe responder a las necesidades de las iniciativas (es decir, la respuesta del siguiente día hábil), proporcionar la información y documentación solicitada de manera oportuna y resolver el problema;
- Contar con Informes del Acuerdo de Nivel de Servicio ("SLA") que incluye la disponibilidad del servicio, interrupciones importantes, Tasa de utilización del servicio y otros indicadores.
  - ✓ Tiempo medio de Atención: menor a 10 minutos.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.3. Arquitectura de Seguridad

Es importante considerar que cualquier empresa que se relacione con la Corporación BancoEstado, que acceda, procese, transmita o almacene información confidencial de propiedad de BancoEstado o de sus clientes, debe cumplir la normativa y estándares de seguridad. El presente documento cubre todos los aspectos de seguridad que se deben satisfacer en el servicio a licitar para el cumplimiento de la normativa y estándares de seguridad de la Corporación BancoEstado.

A continuación, se detallan las especificaciones de seguridad a los proveedores que participarán de la licitación de tal forma que propongan el mejor y más conveniente servicio desde el punto de vista de seguridad para estar en cumplimiento con la normativa vigente de la Corporación BancoEstado.

5.3.1. Requerimientos Generales de Seguridad para el Proveedor del Servicio

5.3.1.1. Gobierno y políticas

- El proveedor del servicio debe estar alineado con la normativa internacional ISO27001 y/o ISO27002. La que deberá acreditar, como parte de los anexos de la propuesta de servicios, con certificación independiente del proceso que sea parte del core de servicio contratado o bien con un GAP análisis de la brecha que este tiene respecto de la referida norma.
- El proveedor del servicio debe mantener un programa de seguridad de la información que le permita asegurar la confidencialidad, integridad, trazabilidad y disponibilidad de los activos de información del Banco y de sus clientes.
- El proveedor del servicio debe contar con una política de seguridad de la información debidamente documentada y conocida por todo su personal.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- El proveedor del servicio debe contar con un plan aprobado por la alta dirección de la empresa proveedora, que considere el proceso de evaluación de riesgos de seguridad de la información asociados a la prestación de servicio, en el cual se consideren y evidencien los riesgos relacionados a los procesos en los que se vea involucrada información de BancoEstado.
- El proveedor del servicio debe contar con procedimientos que permitan mantener la integridad, disponibilidad y confidencialidad de aquella información de BancoEstado que mantiene en sus instalaciones.
- Contar con especialistas certificados o capacitados, en materia de seguridad de la información cuando maneje activos de información de BancoEstado.
- Sus procesos de servicios que soporten activos de información de BancoEstado, deben estar certificados y/o acreditados, de acuerdo a las mejores prácticas de la industria.

5.3.1.2. Disponibilidad y niveles de servicio

- El servicio debe proporcionar un tiempo de respuesta esperado de los sistemas y los niveles de uptime, acorde a lo especificado en las bases de licitación o requerimientos de servicios entregados por BancoEstado. Para esto, el proveedor debe considerar agregar redundancias y mecanismos automáticos de recuperación para las piezas que sean propensas a fallas.
- El proveedor debe proporcionar una solución que permita restaurar sus servicios de acuerdo a las definiciones entregadas por BancoEstado, por ejemplo, RTO (Recovery Time Objective), Uptime, SLA ante escenarios de contingencia o catástrofe.

5.3.1.3. Continuidad

- El proveedor del servicio debe contar con planes de contingencia, orientados a garantizar la continuidad de todos los servicios prestados de acuerdo a los requerimientos de BancoEstado. Debe tenerse en consideración los siguientes escenarios:

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Sin Sistemas.
- ✓ Sin Infraestructura.
- ✓ Ausencia de personal clave.
- ✓ Sin proveedores.
- ✓ Recuperación frente a ataques de Ciberseguridad.
- ✓ Fuera de línea.

- Los planes deben ser probados al menos una vez al año incluyendo, cuando corresponda, el escenario de desastre de sus distintos sitios de procesamiento, debiendo la entidad tomar conocimiento de dicha actividad y verificar los resultados obtenidos.
- Los datos, plataformas tecnológicas y aplicaciones a utilizar en la externalización de los servicios deben encontrarse en sitios de procesamiento específicos y para el caso de procesamiento en el extranjero, en una jurisdicción definida y conocida.
- En cuanto al Centro de Procesamiento de Datos de contingencia, deberá cumplir con las condiciones estipuladas en el capítulo 20-7 de la Recopilación Actualizada de Normas de la Comisión para el Mercado Financiero.
- Para intercambio de información digital con proveedores, toda la información necesaria para la continuidad del negocio, independiente del medio en que resida, debe ser adecuadamente custodiada y su recuperación debe estar garantizada en los tiempos definidos en las bases técnicas del servicio. La suficiencia de los mecanismos de custodia y recuperación deben ser avalados por análisis de Ethical Hacking realizados por terceras partes.
- Los procedimientos de respaldo y recuperación deben incluir mecanismos de seguridad que garanticen su privacidad, evitando accesos no autorizados o su exposición.
- Los procedimientos de recuperación de información deben ser probados en forma permanente, para garantizar la integridad de los datos y su disponibilidad en los tiempos previstos.

5.3.1.4. Auditoría

- Los servicios externalizados expuestos a internet deberán contar con al menos un Ethical Hacking cuatrimestral, realizado por una empresa independiente, con el fin de mantener un control y monitoreo de la infraestructura de seguridad dispuesta por el proveedor. El

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

proveedor debe informar y certificar a BancoEstado que dispone de medidas efectivas de control y protección sobre ataques externos y amenazas mediante informes de auditoría externas y/o Ethical Hacking externos. Los análisis y reportes deben incluir evaluaciones de vulnerabilidad de su infraestructura tecnológica.

- El proveedor del servicio que realice procesamiento o almacenamiento de datos dentro o fuera del país, deberán contar con al menos una auditoría anual, realizada por una empresa independiente, que evalúe la seguridad de la información, los servicios prestados y los mecanismos que permitan prevenir que acciones realizadas por otros clientes afecten negativamente el servicio externalizado por BancoEstado
- El proveedor del servicio debe realizar informes de auditoría asociados a los servicios prestados y dichos informes se encuentran disponibles, para ser consultados en cualquier momento por el Banco y la CMF, en las materias que resulten pertinentes.
- Para toda solución tecnológica que el proveedor disponga como parte del servicio contratado el Banco podrá realizar durante la vigencia del Contrato las pruebas de seguridad que estime pertinentes previa coordinación con el proveedor del servicio.
- El proveedor deberá permitir el acceso permanente, sea mediante visitas a las instalaciones o vía remota, a los registros o datos de información que sean parte del servicio.

5.3.2. Requerimientos Tecnológicos de Seguridad

5.3.2.1. Control de fuga de información y seguridad perimetral

Se requiere que el proveedor del servicio cuente con sistemas de control de fuga de información y seguridad perimetral. Entre estos controles se encuentran los siguientes:

- Control de uso de dispositivos de almacenamiento masivo.
- Control de navegación de internet, para equipos que manejen información confidencial.
- Control de uso de correo electrónico y acceso remoto al correo o escritorio, por parte del personal involucrado en la prestación del servicio.
- Uso de herramientas de control de red perimetral. Entre ellas destacan el uso de Firewalls, sistemas de detección de intrusos (IDS) y sistemas de prevención de intrusos (IPS).

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Infraestructura de red segura. Considera entre otras cosas segmentación de red LAN segura, aislando las redes productivas de las redes de visitas, por citar un ejemplo.
- Controles de seguridad en redes inalámbricas. En caso que el proveedor se conecte a su red a través de conexiones inalámbricas, se requiere que disponga de protocolos seguros de autenticación como WPA2.

5.3.2.2. Equipamiento tecnológico

Se deben cumplir los siguientes requerimientos en todo equipo tecnológico utilizado por el proveedor para prestar el servicio, tanto en las plataformas o equipamiento utilizados para proveer el servicio en si, como el equipamiento utilizado en la red interna del proveedor (por ejemplo, BackOffice, equipos utilizados para mantener la operación del servicio, entre otros):

- El proveedor debe contar con software antivirus/antispam instalado, con licencias y actualizaciones vigentes y al día, en todo aquel equipo que sea utilizado como parte del servicio y que almacene o procese activos de información críticos de BancoEstado o sus clientes.
- Los equipos tecnológicos siempre deben contar con utilizaciones de los últimos parches de seguridad y/o actualizaciones estables, tanto del firmware, Sistema Operativo como de las aplicaciones básicas utilizadas (Internet Information Server, SFTP server, antivirus/antispam, etc) publicadas por los proveedores. Estos deben ser validados técnicamente en ambientes pre-productivos.
- Los servidores utilizados al interior de la red del proveedor, no podrán tener ningún tipo de servicio de red (UDP, RPC, etc.) habilitados, mediante los cuales se comparta información y/o se realice algún tipo de interacción con usuarios o aplicaciones remotas. Se deberán deshabilitar específicamente los siguientes servicios que no cumplan el rol al cual fue designado el servidor:
    - ✓ Servicio WEB (Internet Information Server)
    - ✓ Servicio FTP (Internet Information Server)
    - ✓ Servicio SMTP (Internet Information Server)
    - ✓ Servicio SNMP

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Servicio “Messenger”
- ✓ Servicio “Terminal Services”
- ✓ Servicio “Routing and Remote Access”

- No debe permitirse los directorios compartidos en los servidores por donde se transfiera, procese o almacene activos de información críticos.
- El acceso a puertos administrativos en los servidores debe estar restringido. Para servicios críticos o con manejo de activos críticos de información debe contar con segundo factor de autenticación y para servicios SaaS debe existir restricción por IP origen de los administradores.
- Debe existir acceso restringido o limitado a los puertos de servidores de base de datos.

5.3.2.3. Control de acceso

- El proveedor debe contar con mecanismos que permitan restringir los niveles de acceso a la información confidencial por parte de su personal, en base a las funciones que estos cumplen dentro del servicio. Para medios digitales estos mecanismos deben considerar listas de acceso en las que se detalle cada usuario habilitado y con registro de acciones, fechas y horas. Para medios no digitales deberá mantenerse bitácora de entrada con registro de firmas, fechas y horas.
- El equipamiento usado para generar y/o almacenar claves criptográficas debe estar físicamente protegido, esto es, con control de acceso físico:

Para el caso de las plataformas y aplicaciones se provean como parte del servicio en un sitio externo (nube, hosting) se deben cumplir los siguientes requerimientos de control de acceso:

- Se debe incluir un segundo factor de autenticación para el acceso de usuarios. Se puede incluir sistemas basados en algo poseído.
- El control de acceso a los datos, aplicaciones, servicios o infraestructura, tanto para los usuarios finales como para administradores y soporte técnico, debe ser mediante Active Directory o la base de accesos LDAP vigente en BancoEstado, con cuentas nombradas, o bien en el caso de genéricas, con responsables definidos.
- Las cuentas genéricas que no sean eliminadas deben cumplir con los siguientes requerimientos
  - ✓ Renombrar la cuenta por defecto de administración local de los servidores en la nube.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Las contraseñas de todos los servidores en la nube serán diferentes y no deben tener fecha de expiración.
- ✓ Las contraseñas deben permanecer ensobradas bajo la custodia compartida de la Gerencia de Ciberseguridad y la Gerencia de Riesgos no Financieros de BancoEstado

- Los servidores del proveedor deben contar con una sincronización centralizada de la hora mediante servidores NTP, esto con el fin de evitar divergencias y confusiones a la hora de efectuar un análisis forense o control sobre los registros de eventos. Este control debe aplicar a todos los sistemas en los que sea técnicamente factible, en caso de excepción esta debe ser técnicamente estudiada.
- En el proveedor, usuarios con altos privilegios, deben tener cuentas de usuario personalizadas con privilegios acorde a la función que desempeñan.
- En el proveedor el acceso con cuentas con altos privilegios y de administración, deben generar Log.
- En el proveedor NO debe existir cuentas con altos privilegios genéricos y utilizados por más de una persona.
- Para el caso de aplicativos, el usuario de conexión a bases de datos (cuenta de servicio o usuario sistémico) y la Password debe estar almacenada y protegida en algún archivo de configuración por algún algoritmo que cumpla con los “Requerimientos de Seguridad de Criptografía” del presente estándar. La semilla utilizada para cifrar la UserID y la Password debe ser almacenada en una llave del Registro del Servidor, siendo está protegida por medio de las ACL (Lista blanca de control de acceso) mínimas requeridas.
- Las cuentas sistémicas o Cuentas de Servicio deben poseer privilegios limitados, no deben pertenecer a grupos administradores o aquellos que se consideren de altos privilegios.

Si para la solución propuesta, no aplica este punto, especificar por qué.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.3.2.4. Control de Acceso Perimetral

En el caso que el proveedor para prestar el servicio requiera acceder a Sistemas de BancoEstado, deben cumplir con las siguientes especificaciones:

MODELO DE CONEXIÓN

Las estaciones de trabajo de usuarios de empresas externas que se requieran conectar al Banco deberán realízalo mediante Conexión VPN “Site to Site” o Enlace dedicado.

REQUERIMIENTOS TÉCNICOS

Para dar cumplimiento al modelo de conexión a ser utilizado por este servicio, se requiere que el proveedor cumpla con los requerimientos técnicos detallados a continuación:

- **Estación de trabajo**

Las estaciones de trabajo deben estar en una red dedicada, aislada del resto de la empresa, y conectadas a través de un dispositivo de control hacia BancoEstado. Todo esto será provisto y de costo del proveedor.

- **Comunicaciones**

Tanto el cableado como los equipos de comunicaciones necesarios para la conectividad de los puestos de trabajo en el sitio del proveedor, deben ser adecuados al uso que se les va a dar, y estos deben ser proporcionados y mantenidos por el proveedor.

El proveedor debe tener los elementos de seguridad necesarios para mantener habilitadas las conexiones con BancoEstado. En este sentido, debe hacerse cargo de la contratación, de su administración, soporte y monitoreo. Todos los costos que para ello incurra son de cargo del proveedor.

La Gerencia de Ciberseguridad de BancoEstado es la responsable de recibir los enlaces (conectividad de cada Router). Al finalizar el servicio, se debe proceder a la desconexión del proveedor desde el Datacenter, sin mayor aviso o consulta.

La Gerencia de Ciberseguridad de BancoEstado es responsable de habilitar y administrar las conexiones VPN y de eliminar al darse de baja el servicio.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

En la eventualidad de proporcionar una estación de trabajo VDI a proveedor esta no debe entregar conectividad a Internet.

BancoEstado no debe prestar servicios de conectividad telefónica para Empresas Externas.

- **Seguridad**

El proveedor debe asegurar que solo las estaciones de trabajo autorizadas tendrán tráfico a BancoEstado.

Las estaciones de trabajo permitidas deben estar en una red separada del resto de los dispositivos de la empresa externa, y no pueden conectarse por redes inalámbricas.

Si el proveedor como parte del servicio provee un sitio web, este debe contar con análisis de vulnerabilidad vigente (con una frecuencia de al menos de seis meses). Y debe ser repetido ante cambios importantes en su estructura, infraestructura, lógica o contenido.

Deben realizar análisis de vulnerabilidad web con recursos internos de la empresa proveedora, o bien, indicar que se apoyan en terceros dedicados a este tipo de servicios y que sean previamente validados por BancoEstado.

- **Plan de Contingencia**

Se debe considerar, ante la eventualidad de cualquier situación de amenaza que pudiera ocurrir en el sitio donde éste se provea, un sitio alternativo para dar continuidad al servicio, el cual debe disponer de las mismas condiciones de servicio ya descritas en los párrafos anteriores. Todo esto debe ser provisto y de cargo del proveedor.

5.3.2.5. Desarrollo Seguro de Software

Para cualquier aplicativo desarrollado (o por desarrollar) que el proveedor utilice para proveer el servicio, se deben cumplir los siguientes requerimientos de desarrollo seguro:

- El proveedor debe tener una metodología de desarrollo que incluya procedimientos documentados que soporten y guíen el desarrollo de las aplicaciones que utilizarán para la corporación BancoEstado.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- La Seguridad de la Información debe estar involucrada desde el principio de la definición de las nuevas aplicaciones hasta el final de las mismas, cuando son implementadas para asegurar que todo el ciclo de vida del software esté cubierto desde el punto de vista de la seguridad de la información.
- Debe existir separación de ambientes en el centro de datos del proveedor, de manera tal que se cumpla los siguientes requerimientos:
    - ✓ Los entornos de desarrollo y pruebas estén separados.
    - ✓ Las reglas permitidas entre ambientes deben ser las mínimas e indispensables para asegurar que los traspasos a producción puedan ser realizados.
    - ✓ En caso que los traspasos a producción sean de sistemas completos, deben existir procedimientos que aseguren la eliminación de datos y usuarios de pruebas.
    - ✓ Nunca deben utilizarse datos reales de producción en los ambientes de prueba y desarrollo, así como por ejemplo activos de información críticos tales como: número completo de tarjeta (PAN), movimiento de la cuenta de los clientes, entre otros. Una persona de desarrollo y/o de prueba nunca debe poder acceder a los entornos de producción, asegurando de esta manera el criterio de separación de funciones.
- En la construcción de la plataforma se debe seguir los requerimientos indicados en la sección CODIFICACION SEGURA
- El software debe cumplir con los siguientes requerimientos relacionados con la identidad de los usuarios:
    - ✓ Se debe autenticar a las personas que acceden al sistema, mediante ID (identificadores de usuarios únicos y personalizados) y Password (debidamente protegidos mediante algún tipo de cifrado).
    - ✓ La aplicación NO debe permitir UserID duplicados o en blanco.
    - ✓ El ID de un Usuario debe crearse acorde a la nomenclatura estándar, según la definición corporativa.
    - ✓ Como mínimo se deben incluir dos campos descriptivos, uno para nombre completo del usuario y otro para el cargo o función.
    - ✓ Los aplicativos deben garantizar privilegios a los usuarios en base a roles, es decir, deben seguir el modelo RBAC para manejo de permisos. La aplicación debe permitir realizar

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

una adecuada segregación de funciones (administrador de seguridad, auditor, supervisor de aplicación, operador u otro).

- ✓ No se permite múltiples instancias de login de los UserID.
- ✓ NO se debe utilizar usuarios genéricos.
- ✓ Cualquier acción realizada por usuarios debe ser auditable.

- En relación a la administración de usuarios se debe cumplir:
  - ✓ El módulo de administración de usuarios y permisos del nuevo aplicativo, debe permitir:
    - Asignar solo un perfil o grupo funcional por usuario, no opciones individuales.
    - Administrar perfiles y grupos asignados a cada usuario.
  - ✓ El control de acceso se logrará mediante la generación de: reportes de usuarios, reportes de grupos, reportes de usuarios y grupos asociados, reportes de grupos y opciones asociadas.
  - ✓ Al dar de baja una cuenta de usuario se deben revocar todos los privilegios otorgados, tanto a través del módulo de administración como de las tablas de base de datos.
  - ✓ La aplicación debe registrar eventos relacionados con aspectos de seguridad del sistema, así como también generar un archivo Log, de acuerdo a lo definido en el "Estándar de Log de Eventos".
  - ✓ La información de los log de seguridad y transacciones no deben ser modificables, de acuerdo a lo definido en el "Estándar de Log de Eventos".

- La plataforma debe generar registros de auditoría de tal forma que provea las evidencias necesarias para mantener el principio de no repudio cumpliendo con los siguientes requerimientos:
  - ✓ Integrar la capacidad de registro en todas las opciones de la aplicación, con el propósito de proveer los elementos necesarios para realizar algún tipo de seguimiento a la actividad requerida.
  - ✓ Proveer un proceso automático que elimine todos los registros dado un período de vigencia.
  - ✓ Proveer de mecanismos de generación de reportes y consultas.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Asegurar la NO modificación del registro de la actividad y que solo pueda ser accedido por usuarios autorizados.

- La plataforma debe ser sometida a pruebas de vulnerabilidad y o penetración bajo los siguientes requerimientos:
  - ✓ Se deben realizar pruebas de vulnerabilidades y penetración antes prestar el servicio a BancoEstado. Posteriormente durante la operación se deben hacer las pruebas ante cualquier cambio los aplicativos en su estructura, infraestructura, lógica o contenido y por otro lado pruebas periódicas con frecuencia mínima de un año
  - ✓ El proveedor debe efectuar pruebas de vulnerabilidades que deben ser ejecutadas en ambiente pre-productivo contando con una re-certificación de la aplicación antes de la implementación de cualquier modificación de código y deben ser realizadas en forma manual por personal idóneo, o bien automáticamente, utilizando herramientas de escaneo de vulnerabilidades.
  - ✓ Las pruebas de vulnerabilidades como mínimo deben incluir las pruebas necesarias para detectar vulnerabilidades que son frecuentes en los siguientes ámbitos de codificación:
    - Validación de entradas
    - Codificación de salidas
    - Administración de autenticación y contraseñas
    - Administración de sesiones
    - Control de Acceso
    - Prácticas Criptográficas
    - Manejo de errores y Logs
    - Protección de datos
    - Seguridad en las comunicaciones
    - Configuración de los sistemas
    - Seguridad de Base de Datos
    - Manejo de Archivos
    - Manejo de Memoria
  - ✓ Cualquier detección de una vulnerabilidad debe ser remediada previo a la puesta en producción.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Los análisis de vulnerabilidad que se realicen al servicio de nube deben ser ejecutados por alguno de los proveedores que BancoEstado considera como confiables para estos análisis y a costo del proveedor.
- ✓ Los resultados de las pruebas de vulnerabilidad deben ser entregados a BancoEstado y de forma interna en el Banco ser aprobados por la Gerencia de Ciberseguridad e informada su aprobación a la Gerencia de Riesgos no Financieros y a la Subgerencia de Integración y Servicios Tecnológicos.

5.3.2.6. Codificación Segura

Cualquier aplicativo o plataforma Web que el proveedor exponga para proveer el servicio debe estar construido en bases a las mejores prácticas de codificación segura de la industria de tal forma de prevenir y/o mitigar las amenazas y vulnerabilidades que se encuentran de forma más frecuente en las aplicaciones Web y que se encuentran identificadas y catalogadas por organismos especializados en seguridad tales como OWASP (Open Web Application Security Project), WASC (Web Application Security Consortium) y NIST (National Institute of Standards and Technology) y que también para algunos casos se encuentran identificadas en los requisitos de PCI DSS (requisito 6 “Desarrolle y mantenga sistemas y aplicaciones seguras”).

Los requerimientos de codificación segura están orientado a aplicar controles en los siguientes ámbitos del software:

- Validación de entradas
- Codificación de salidas
- Administración de autenticación y contraseñas
- Administración de sesiones
- Control de Acceso
- Prácticas Criptográficas
- Manejo de errores y Logs
- Protección de datos
- Seguridad en las comunicaciones
- Configuración de los sistemas

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Seguridad de Base de Datos
- Manejo de Archivos
- Manejo de Memoria

5.3.2.7. Criptografía

Los activos de información críticos de BancoEstado que se utilicen en el servicio, deben ser cifrados (encriptados), manteniéndose las llaves de encriptación en poder de BancoEstado, de acuerdo a lo indicado en el "Estándar de Criptografía". Asimismo, se deben definir los procedimientos de intercambio de claves entre el proveedor de servicios y el Banco, además de establecerse los roles y responsabilidades de las personas involucradas en la administración de la seguridad. Todos los activos de información críticos dentro de sistemas y componentes que los almacenen, procesen o transmitan, deben estar cifrados utilizando algoritmos de cifrado fuerte. Todas las claves criptográficas deben estar protegidas contra modificación, pérdida y destrucción. Todo lo anterior en base a los siguientes requerimientos:

- Todos los activos de información críticos, incluyendo datos de tarjetahabiente y datos de autenticación dentro de sistemas y componentes que los almacenen, procesen o transmitan, deben estar cifrados utilizando algoritmos de cifrado fuerte, igual o mayor a 128 bits, tal como se detalla en la siguiente tabla:

Fuerza de Cifrado	Algoritmos Simétricos	Algoritmos Hash	Algoritmos ECC	Algoritmos (RSA/DSA/DH)
128-bits	AES-128	SHA-2 (256)	256-bits	3072-bits
192-bits	AES-192	SHA-2 (384)	384-bits	7680-bits
256-bits	AES-256	SHA-2 (512)	512-bits	15360-bits

- Cuando el uso de las llaves de cifrado corresponda a algoritmos simétricos, el propietario de las llaves debe ser BancoEstado y será este quien tenga la custodia de la llave de descifrado. En el caso de algoritmos asimétricos, el dueño de cada llave es el responsable de custodiar su llave privada y compartir la llave pública.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Todas las claves criptográficas deben estar protegidas contra modificación, pérdida y destrucción.
- Se debe asegurar el retiro o reemplazo de las claves criptográficas cuando la integridad de las mismas haya sido debilitada, por ejemplo, la salida de un empleado con el conocimiento de un componente clave en texto claro, o cuando se sospeche que las llaves pueden haber sido comprometidas.
- Deben existir controles que prevengan la sustitución no autorizada de claves criptográficas.
- Se debe exigir la aceptación formal (en papel firmado o electrónicamente) que los custodios de las llaves criptográficas entienden y están de acuerdo con los riesgos y responsabilidades asociadas a esta función
- Deben existir procedimientos definidos que protejan las llaves de cifrado de posibles brechas de seguridad o mal uso de las mismas y que aseguren los siguientes puntos:
    - ✓ Se debe restringir el acceso a las claves criptográficas al mínimo número de custodios posibles.
    - ✓ Debe(n) existir un procedimiento(s) de intercambio dinámico de llaves.
    - ✓ Se deben almacenar las llaves privadas utilizadas para cifrar y descifrar los mensajes, utilizando algunas de las siguientes formas:
        - Llaves de cifrado de claves, que sea al menos tan sólidas como la clave de cifrados de datos y que se almacene separada de la clave de cifrado de datos.
        - Dentro de un dispositivo criptográfico seguro, tal como un módulo de seguridad de host (HSM) o un dispositivo de punto de interacción (PTS) aprobado por el PCI Council.
        - Procedimiento de clave y custodia dual, en concordancia con métodos aceptados por la industria.
        - Almacenando las llaves en el mínimo número de lugares posible, ensobradas y custodiadas bajo caja de seguridad.
    - ✓ La responsabilidad de las claves debe corresponder a las Gerencias que custodian de las mismas.
- Se deben documentar los procedimientos para la gestión de claves criptográficas utilizadas para el cifrado de datos de titulares de tarjetas, incluyendo los siguientes requerimientos:

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- ✓ Generación de llaves criptográficas fuertes (se recomienda un espacio de claves mayor o igual al generado por una llave de 15 caracteres de longitud, utilizando un conjunto de caracteres que incluyan letras mayúsculas y minúsculas, números y caracteres especiales).
- ✓ Distribución segura de llaves criptográficas. Éstas deben ser enviadas a los custodios vía métodos de transmisión segura, al menos https o sftp, y a su vez deben estar cifradas a nivel de dato durante la transmisión, según el "Estándar de Transferencia de Información" utilizando una llave de cifrado que sea enviada a los custodios por vías independientes a las utilizadas para enviar la llave original cifrada.
- ✓ Almacenamiento seguro de llaves, según los métodos nombrados anteriormente.

5.3.2.8. Servicios de Red

La infraestructura tecnológica que se dispone para proveer el servicio debe cumplir con los siguientes requerimientos de seguridad a nivel de conexión o comunicación:

- Los datos en tránsito deben transmitirse mediante protocolos seguros.
- Los protocolos reconocidos como seguros son:
  - ✓ TLS v1.2 o superior
  - ✓ SSH v2 o superior
  - ✓ HTTPS sobre TLS v1.2 o superior
  - ✓ SFTP
  - ✓ FTPS
  - ✓ SNMPv3
  - ✓ SMTPS
  - ✓ IMAPS
  - ✓ RDP sobre TLS v1.2 o superior
- La implementación de estos protocolos debe ser tal que aseguren un nivel de cifrado de 128 bits o superior.
- No deben usarse protocolos inseguros. Protocolos inseguros son todos aquellos que no tienen un nivel de cifrado fuerte (igual o mayor a 128 bits) y, adicionalmente, no ofrecen niveles de

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

autenticación razonables. Ejemplos de estos protocolos son FTP, Telnet, POP3, IMAP, y SNMP v1 y v2., RSH, SOAP.

- Solo se debe habilitar los servicios necesarios que permitan la operación normal de las funciones del sistema de negocio, tal como: conexiones, puertos y protocolos en los equipos servidores y firewalls, soportadas por la infraestructura del entorno de datos.
- Todo envío de contraseñas debe realizarse vía protocolos seguros de comunicación. Las contraseñas se deben almacenar en forma cifrada y ser transmitidas en forma protegida, de acuerdo a lo establecido en la sección de CRIPTOGRAFIA.
- Los certificados digitales deben estar generados desde TLS 1.2 bajo el estándar X.509v3 con una llave de cifrado de largo 2048bits y firmado con el algoritmo SHA256.
- Para servicios productivos expuestos a internet, el certificado debe ser generado por una autoridad certificadora pública

5.3.2.9. Transferencia de información

El proveedor del servicio debe contar con procedimientos escritos que describan el proceso de intercambio de información con BancoEstado, o con terceras partes. Estos procedimientos deben incluir las consideraciones necesarias que permitan garantizar la integridad, confidencialidad y disponibilidad de la información intercambiada, al menos incluyendo lo siguiente:

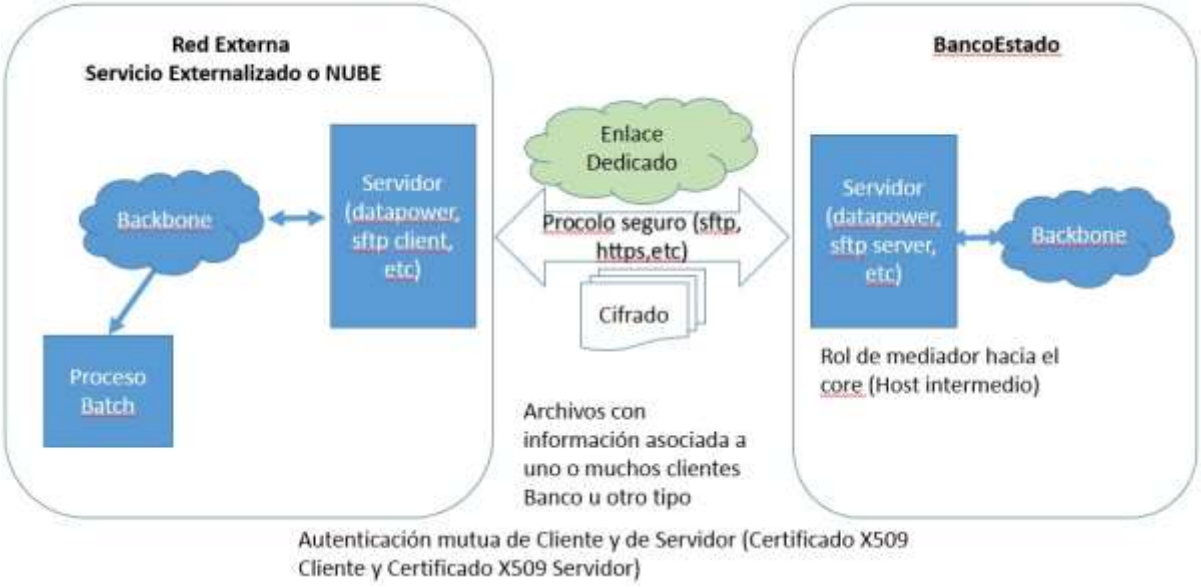
- • Procedimientos para el control, notificación, envío, despacho y recepción.
- • Procedimientos para asegurar la trazabilidad y no repudio.
- • Acuerdos de custodia.
- • Responsabilidades y obligaciones en el evento de incidentes de seguridad, tales como la pérdida de datos.

Las conexiones de comunicaciones entre BancoEstado y el Proveedor de servicios deben contar con un nivel de cifrado que asegure la confidencialidad y la integridad de los datos de punta a punta (“end to end”). Para la transferencia de información en términos tecnológicos se debe cumplir lo siguiente:

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

CASO 1: Transferencia de información On-Line

Para el caso de Integración B2B con servicios Web se debe cumplir los siguientes requerimientos:



Asegurar el canal de comunicación.

La conectividad entre una red externa y BancoEstado, se debe establecer mediante un enlace dedicado. Se entiende como “Enlace dedicado” a un enlace privado habilitado entre las dependencias del proveedor y un Carrier, y entre este Carrier y BancoEstado. Se requiere que estos enlaces dedicados utilicen las redes Multipunto, o entronques que el Banco pone a disposición para esto. Se deben utilizar los protocolos seguros establecidos como estándar por BancoEstado, en este caso HTTPS

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

BancoEstado utilizará una lista blanca (ACL), para que solo las IPs del proveedor puedan acceder a los servicios expuestos por BancoEstado. En caso que el proveedor exponga servicios, este también debe utilizar listas blancas para permitir el acceso solo a las IPs de BancoEstado.

Los certificados digitales deben estar generados desde TLS 1.2 bajo el estándar X.509v3 con una llave de cifrado de largo 2048bits y firmado con el algoritmo SHA256. Para servicios productivos el certificado debe ser generado por una autoridad certificadora pública.

Asegurar el dato/mensaje en tránsito

Todos los activos de información críticos, incluyendo datos de tarjetahabiente y datos de autenticación dentro de sistemas y componentes que los almacenen, procesen o transmitan, deben estar cifrados utilizando algoritmos de cifrado fuerte, igual o mayor a 128 bits de acuerdo a lo indicado en la sección de criptografía.

Asegurar la autenticación.

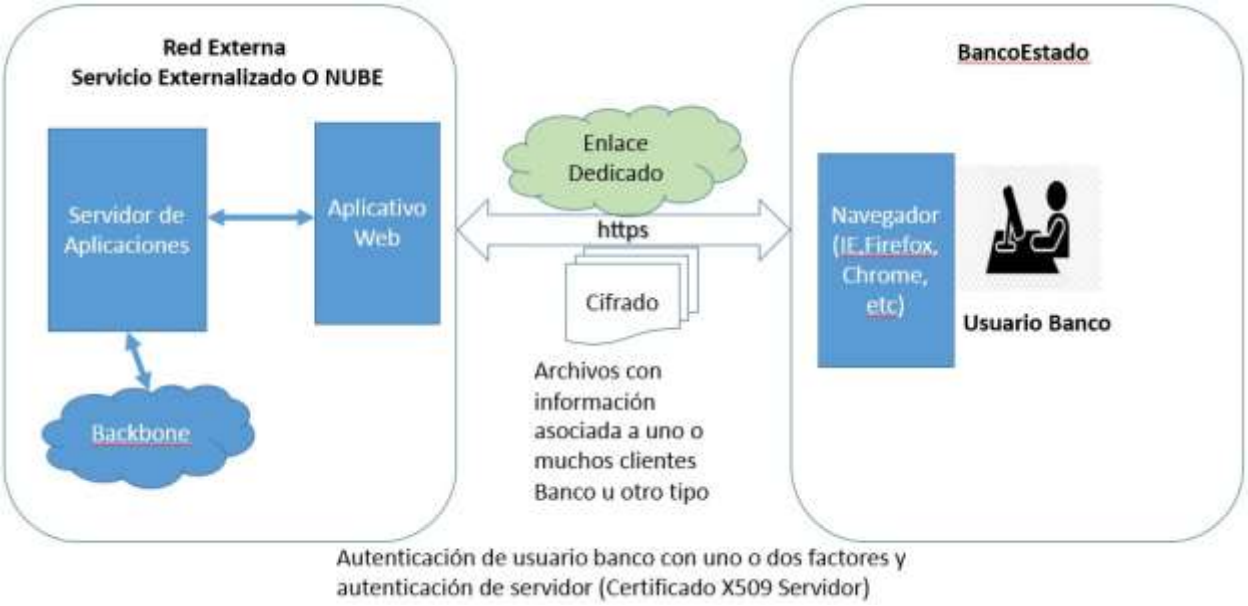
Para asegurar la autenticación de los servicios, se pueden utilizar certificados o llaves en ambos extremos para la validación del Cliente y del Servidor (Autenticación mutua). Esto se puede lograr con uno de los siguientes mecanismos:

a) A nivel de capa aplicativa o mensaje: Autenticación a través de firma digital, bajo el esquema de llaves pública y privada, utilizando los algoritmos asimétricos de cifrado especificados en este estándar. Por ejemplo y dependiendo de la implementación se tienen: JSON Web Tokens, XML Digital Signature entro otros.
b) A nivel de capa de transporte: Utilizando certificados o llaves pública y privada para autenticación mutua a nivel de protocolos seguros. Por ejemplo: Certificado TLS cliente y certificado TLS servidor para autenticación mutua, par de llaves pública y privada del cliente y para de llaves pública y privada del servidor para autenticación mutua a nivel de SSH.

CASO 2: Transferencia de archivos entre usuario Banco y Red externa/Nube

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Para este tipo de transferencia de archivos, se deben implementar las siguientes medidas de seguridad:



Asegurar el canal de comunicación.

La conectividad entre una red externa y BancoEstado, se debe establecer mediante un enlace dedicado. Se entiende como “Enlace dedicado” a un enlace privado habilitado entre las dependencias del proveedor y un Carrier, y entre este Carrier y BancoEstado. Se requiere que estos enlaces dedicados utilicen las redes Multipunto, o entronques que el Banco pone a disposición para esto.

Se deben implementar protocolos seguros establecidos como estándar por BancoEstado, en este caso se trata del protocolo HTTPS para asegurar un nivel de cifrado seguro del canal.

Los certificados digitales deben estar generados desde TLS 1.2 bajo el estándar X.509v3 con una llave de cifrado de largo 2048bits y firmado con el algoritmo SHA256. El certificado se requiere para el lado servidor. Para servicios productivos el certificado debe ser generado por una autoridad certificadora pública.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

El proveedor debe utilizar listas blancas (ACL) para permitir el acceso solo a las IPs de BancoEstado.

Asegurar el archivo en tránsito.

Los archivos con información Confidencial asociada a uno o varios clientes de BancoEstado u otro tipo, debe permanecer cifrada desde su origen. Se debe utilizar un sistema de cifrado de clave pública y privada bajo el estándar OpenPGP, el cual debe seguir los siguientes requerimientos:

Se debe utilizar un esquema de clave asimétrica, esto es un modelo de claves privadas y públicas.

La empresa que genera el archivo debe encriptar con la clave pública de la empresa de destino, lo que asegura que solo el destinatario que posea la clave privada correspondiente pueda descifrar el archivo.

BancoEstado siempre es quien va a dejar o buscar información en una transferencia de información.

BancoEstado debe disponer de un Software que opere como cliente para la transferencia segura de información confidencial.

Los usuarios de conexión deben ser bloqueados en caso de no estar en uso. De manera planificada y automáticamente de acuerdo a lo estipulado en el “Estándar de Control de Acceso”.

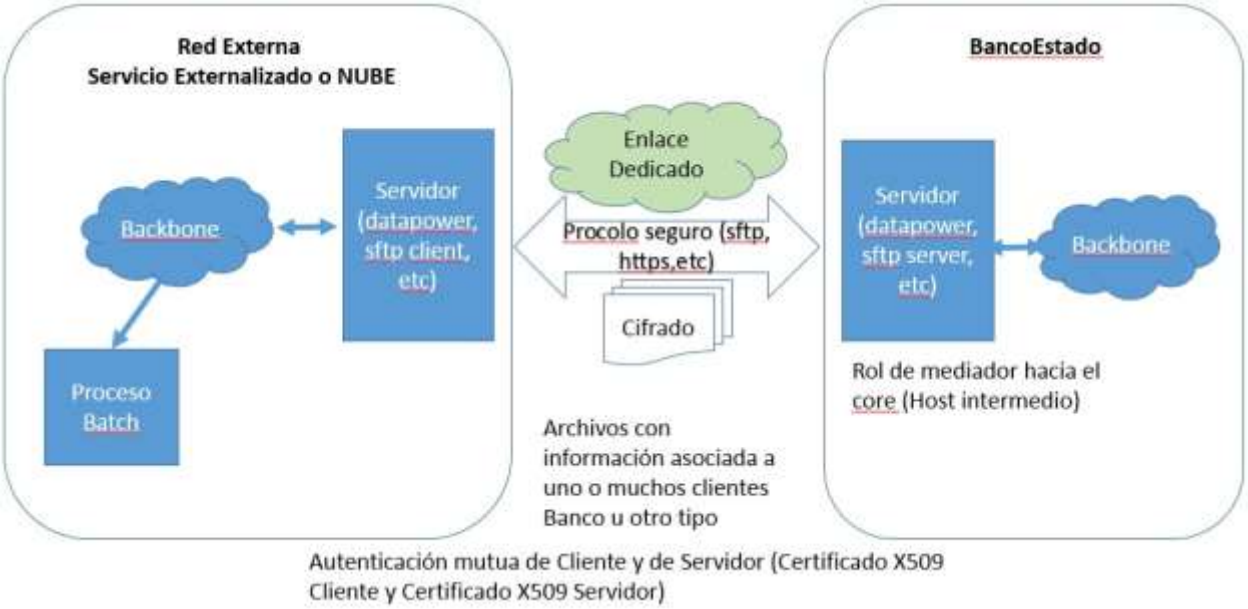
Asegurar la autenticación.

Los aplicativos BancoEstado (sean estos desarrollados en forma interna o bien aquellos denominados paquetes cerrados) en los cuales los usuarios finales son personal de BancoEstado, ya sean internos o externos, deben ser integrados con los elementos y componentes de seguridad que se encuentren vigentes de acuerdo a lo definido en el documento de Arquitectura de referencia vigente, para implementar el control de acceso en términos de autenticación y autorización (Active Directory y SISPERM).

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Para ejecutar esta acción el usuario BancoEstado debe estará autorizado por la Gerencia de Riesgos no Financieros.

CASO 3: Transferencia de información confidencial B2B (Banco y Red externa/Nube)



Asegurar el canal de comunicación.

La conectividad entre una red externa y BancoEstado, se debe establecer mediante un enlace dedicado. Se entiende como “Enlace dedicado” a un enlace privado habilitado entre las dependencias del proveedor y un Carrier, y entre este Carrier y BancoEstado. Se requiere que estos enlaces dedicados utilicen las redes Multipunto, o entronques que el Banco pone a disposición para esto.

Se deben implementar protocolos seguros establecidos como estándar por BancoEstado, que en este caso son **SFTP** o **FTPS**.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Para establecer la conexión segura, dependiendo del protocolo elegido, se deben utilizar certificados digitales o el modelo de claves asimétricas o simétricas.

BancoEstado utilizará una lista blanca, para que solo la IP del proveedor pueda acceder a los Web Services de BancoEstado.

Asegurar el archivo en tránsito.

Los archivos con información Confidencial asociada a uno o varios clientes de BancoEstado u otro tipo, debe permanecer cifrada desde su origen. Se debe utilizar un sistema de cifrado de clave pública y privada bajo el estándar OpenPGP, el cual debe seguir los siguientes requerimientos:

Se debe utilizar un esquema de clave asimétrica, esto es un modelo de claves privadas y públicas.

La empresa que genera el archivo debe encriptar con la clave pública de la empresa de destino, lo que asegura que solo el destinatario que posea la clave privada correspondiente pueda descifrar el archivo.

BancoEstado siempre es quien va a dejar o buscar información en una transferencia de información.

BancoEstado debe disponer de un Software que opere como cliente para la transferencia segura de información confidencial.

Los usuarios de conexión deben ser bloqueados en caso de no estar en uso. De manera planificada y automáticamente de acuerdo a lo estipulado en el “Estándar de Control de Acceso”.

Asegurar la autenticación.

Para asegurar la autenticación entre los servicios o aplicativos de BancoEstado y los proveedores, se pueden utilizar certificados o llaves en ambos extremos para la validación del Cliente y del Servidor (Autenticación mutua).

No se recomienda el uso de usuario y contraseña para establecer la sesión.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

La contraseña nunca debe viajar en texto claro.

Se debe proteger la transferencia de información para servicios Batch, con protocolo PGP y protocolo de transferencia segura:

Para proteger los activos de información, se debe utilizar un esquema de clave asimétrica, esto es, un modelo de claves privadas y públicas.

Con el fin de garantizar la integridad y confidencialidad de la información a transferir entre dos empresas, se debe aplicar el siguiente criterio: si es el proveedor el que enviará la información encriptada, el par de claves debe ser generado por BancoEstado compartiendo la clave pública al proveedor, el nombre dado a la clave debe ser nemotécnico asociado a la empresa con la que se está realizando la transferencia. Si es BancoEstado quien enviará la información encriptada, el par de claves debe ser generado por el proveedor compartiendo la clave pública con BancoEstado.

La empresa que transfiere debe encriptar con la clave pública del destinatario.

BancoEstado debe tener el rol de cliente en una transferencia de información vía SFTP entre el proveedor de servicio de nube.

La empresa proveedora de servicios de nube al BancoEstado, debe proveer los datos de usuarios y contraseñas que deben ser utilizados a nivel cliente por parte de BancoEstado, de acuerdo a lo estipulado en la sección de Requerimientos de Seguridad de Control de Accesos.

5.3.2.10. Log de eventos

El Proveedor debe contar con registro de logs en sus sistemas que permita realizar una trazabilidad de las actividades realizadas en sus plataformas en caso de incidentes de seguridad.

Las plataformas o sistemas utilizados para prestar el servicio deben generar logs de eventos que deben cumplir los siguientes requerimientos:

El proveedor debe mantener un control de las actividades de sus usuarios que tratan información de la Corporación BancoEstado, de acuerdo a los niveles de confidencialidad establecidos.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Los sistemas utilizados para prestar el servicio deben generar logs que contengan por cada evento, la siguiente información como mínimo:

Cuando:

- Fecha
- Hora Dónde:
- Identificador de aplicación. Como mínimo: Nombre y versión
- Dirección IP y Servicio (Nombre del servicio/protocolo)
- Ventana/Formulario/Página (por ejemplo, nombre de la ventana, nombre del formulario, URL de donde se gatillo el evento, etc)
- Ubicación en el código Por ejemplo: nombre del script, nombre del módulo. - Geo-posición Quién:
- Dirección IP origen
- ID de usuario Qué:
- Tipo de evento
- Severidad del evento (fatal, error, warning, info, debug, trace)
- Descripción
- Acción original que gatillo el evento (Log-in, Log-out, actualización de perfil, transacción específica, etc)
- El objeto Resultado:
- Resultado de la operación

• La siguiente información no debe registrarse en los logs de eventos:
  - Código fuente de la aplicación.
  - Identificadores de sesión.
  - Tokens de acceso.
  - Strings de conexión a bases de datos.
  - Llaves de cifrado.
  - Información de entrada de fuentes inseguras sin sanear (limpieza de caracteres especiales que puedan producir un ataque de seguridad, por ejemplo log forging).

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Información confidencial Nivel 1 y 2 de acuerdo a la clasificación de información confidencial BancoEstado.

- Se debe contar con una sincronización centralizada de la hora en los equipos (NTP) para evitar divergencias y confusiones a la hora de efectuar un análisis forense o control sobre los registros de eventos.

5.3.2.11. Respaldo de Información

Respecto a la información que reside en medios magnéticos, ésta debe ser respaldada con una periodicidad y en forma tal que minimice el riesgo de pérdida de información, alineados a los requerimientos indicados en los párrafos que siguen.

Los procedimientos de recuperación de información deben ser probados sujeto a la periodicidad de los contratos y a si la información se respalda o no en el Banco o si existen exigencias normativas, se deben cumplir de acuerdo a esta exigencia, por ejemplo bajo las políticas de respaldo banco y de mantener en chile un respaldo del aplicativo como de datos en caso que estos la empresa proveedora los mantenga fuera de Chile.

Los procedimientos de respaldo y recuperación deben incluir mecanismos de seguridad que garanticen su privacidad, evitando accesos no autorizados o su exposición. Las medidas deben contemplar cifrado de datos en medios digitales aplicando lo indicado en la sección de CRIPTOGRAFÍA y medidas de seguridad físicas para medios tangibles. La suficiencia de estos debe ser documentada con certificaciones, auditorías externas o un informe de análisis de riesgos propio del proveedor.

El proveedor debe cumplir con los siguientes requerimientos específicos de respaldo en la plataforma tecnológica y que almacene, procese o transmita información de BancoEstado:

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Todos los respaldos deben ser almacenados en sitios asegurados físicamente, preferentemente, deben estar guardados en sitios diferentes a los Centros de Datos, donde la misma información se encuentra presente en servidores.
- Todos los activos de información críticos, incluyendo datos de tarjetahabiente dentro de los respaldos, deben estar cifrados utilizando algoritmos de cifrado fuerte mayor o igual a 128 bits, tal como se indica en sección de CRIPTOGRAFÍA.
- Debe existir un inventario y un control del período de retención de la información que incluya a todos los medios que manejan información crítica. Los medios donde la información haya superado el período de retención deben ser reutilizados o destruidos en forma segura, según la sección “Borrado y Destrucción Segura de Información”.
- Se requiere que todos los medios sean clasificados y etiquetados de manera tal que los operadores sepan cuando se trata de información crítica la que se encuentra almacenada en estos, la referencia debe ser un código interno.
- Los medios de respaldo que deban ser destruidos, deben seguir las especificaciones de la sección BORRADO Y DESTRUCCIÓN SEGURA DE INFORMACIÓN cuando se rompan, haya llegado al período de vida útil, o cuando ya no sea necesario guardarlos por motivos comerciales o legales.
- Deben existir copias de respaldo y que se deben almacenar en lugares apartados, a distancia suficiente como para escapar de cualquier daño por un desastre en el local principal, de acuerdo a las necesidades de disponibilidad y a las condiciones establecidas por los organismos reguladores.
- Se deben realizar pruebas periódicas a aquellos medios de respaldos que por su naturaleza no son requeridos frecuentemente con el fin de asegurar la disponibilidad e integridad de recuperar la información, con la validación del dueño de la información.
- Se deben documentar las pruebas realizadas, indicando a lo menos: el responsable, fecha de la prueba, resultados obtenidos, excepciones y actividades realizadas.

5.3.2.12. Borrado y destrucción segura de información

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

El proveedor debe cumplir con los siguientes requerimientos de borrado y destrucción segura de información en la plataforma tecnológica y que almacene, procese o transmita información de BancoEstado:

- Todos los medios que soporten datos, deben ser retenidos por un periodo definido en base a las necesidades de negocio o entes reguladores.
- En el inventario de activos de información, se debe considerar al menos la siguiente registros:
  - ✓ Responsable de los activos de información.
  - ✓ Tipo de medio el cual se encuentra almacenada los activos de información.
  - ✓ Ubicación física donde estos medios se almacenan.
- Todos los medios que no son necesarios para la operación del negocio, ya sea por razones legales o que hayan llegado al límite de su vida útil, deben ser destruidos en forma segura.
- Los métodos de destrucción segura para medios de almacenamiento de respaldos de información, deben asegurar el borrado de la información. Dentro de los métodos se encuentran, pero no se limitan a los siguientes:
  - ✓ Destrucción física del medio
  - ✓ Degaussing
  - ✓ Borrado seguro de los datos
- Las herramientas y/o métodos propuestos para el borrado seguro de los datos son los siguientes:
  - ✓ DoD 7
  - ✓ Gutmann

  Estos métodos pueden ser implementados por programas como sdelete para plataformas Windows y shred para plataformas Linux y/o Unix.

- Los medios de almacenamiento que sean solicitados por proveedores para su recambio, deben ser destruidos en forma segura y debe quedar asociado al NDA de los proveedores.
- Para los medios removibles que se encuentren bajo obsolescencia tecnológica, en reparación o con problemas permanentes, se deberá asegurar su borrado de forma segura.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

5.3.2.13. Requerimientos de Seguridad en Datos en Reposo en la Nube o Sitio externo

Las Bases de Datos o Archivos que contengan activos de BancoEstado deben ser protegidas de accesos no autorizados mediante herramientas de monitoreo y protección de Base de Datos, mecanismos de control de acceso y cifrado, de acuerdo a los siguientes requerimientos:

El acceso a los datos debe ser de acuerdo a lo definido en la sección de CONTROL DE ACCESO

Cifrar las interfaces o archivos que contengan activos de información críticos, según los requerimientos de seguridad de la sección de CRIPTOGRAFÍA.

Se deben controlar las acciones no autorizadas de los usuarios, mediante herramientas de control como correlacionador de eventos.

5.3.2.14. Centros de datos (Datacenter) e infraestructura TI

Los proveedores de servicio de hosting, no deben compartir la infraestructura con otro cliente, cuando se traten de servicios y/o aplicaciones que procesen, transmiten o almacenen activos de información críticos , salvo que estos sean multitenant (infraestructura diseñada para soportar múltiples clientes) y posean características para garantizar el total aislamiento entre cliente.

Los centros de cómputo del proveedor deben cumplir con al menos las siguientes características:

- Data Center certificado Tier III – Uptime Institute
- Configuración con respaldo redundante en todo su equipamiento

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

- Los centros de procesamiento de datos, principal y contingencia, se deben mantener homologados en la infraestructura tecnológica y versiones de software, y operando preferentemente en modalidad activo-activo, según diseño de arquitectura aprobado.
- La configuración de los sitios debe disponer de una infraestructura de telecomunicaciones y de equipamiento computacional con la redundancia necesaria para evitar puntos únicos de falla; con medios de comunicación distintos en sus trayectorias; y gestionado por especialistas, de manera de proporcionar soporte técnico que funcione de acuerdo con las necesidades del negocio y operando preferentemente en modalidad 24x7.
- Los Data Centers de BancoEstado o de proveedores que procesen o almacenen información de BancoEstado debe contar con infraestructura y procedimientos de respaldo que permiten recuperar los datos, software básico y aplicativo, ante una contingencia o corrupción de la información de acuerdo con los RPO y RTO establecidos.
- El Centro de Procesamiento de Datos de contingencia, debe cumplir con condiciones de ubicación y distancia del Centro de Procesamiento de Datos principal, que garanticen la continuidad operacional.
- El Banco debe efectuar el control y monitoreo del servicio externalizado en el Centro de Procesamiento de Datos en el exterior, especialmente, en los aspectos relacionados con la seguridad de la información, continuidad del negocio y condiciones de operación del centro de procesamiento. Dichas actividades deben estar debidamente fundamentadas de acuerdo a la gestión de riesgos realizada para el proveedor específico. Lo anterior, independientemente de las actividades propias de control y monitoreo que realice el proveedor del servicio.
- El equipamiento debe estar diseñado para ser instalado en rack y anclado (superior e inferior).
- El equipamiento debe poseer redundancia eléctrica (doble fuente), conectadas a fases o circuitos eléctricos distintos.
- El equipamiento a Instalar debe cumplir la normativa S.E.C (NCH Eléctrica 4/2003).
- No se debe aceptar la instalación de dispositivos hechizos o modificados. Cada equipo nuevo debe ser rotulado, además del cable de energía y conexiones.

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile

Bases Técnicas – BancoEstado © Documento Propiedad de Banco del Estado de Chile